Jr.Pen 4. NMAP

1. NMAP Basics

1. Introduction

If asked to uncover which devices are live on the 192.168.0.1/24 network, one can use basic tools such as ping, arp-scan, or some other tool to check the 254 IP addresses. Although this network has 256 IP addresses, we counted 254 IP addresses because two are reserved. Each tool has its limitations. For example, ping won't give any information if the target system's firewall blocks ICMP traffic. Moreover, arp-scan only works if your device is connected to the same network, i.e., over Ethernet or WiFi. One can use telnet to try one port after the other; however, with thousands of ports to scan, this can be a very time-consuming task, even if a script was created to automate the telnet connection attempts. A very efficient solution that can solve the above two requirements and many more is the Nmap network scanner.

2. Host Discovery: Who Is Online

Nmap can be used to discover which hosts are currently online on a network. Scanning a "Local" Network: `nmap -sn 192.168.66.0/24` command and its output are shown in the terminal below. As mentioned earlier, `-sn` aims to discover live hosts without attempting to discover the services running on them. This scan might be helpful if you want to discover the devices on a network without causing much noise. However, this won't tell us which services are running.

```
root@tryhackme:~# nmap -sn 192.168.66.0/24
Starting Nmap 7.92 ( https://nmap.org ) at 2024-08-07 13:49 EEST
Nmap scan report for XiaoQiang (192.168.66.1)
Host is up (0.0069s latency).
MAC Address: 44:DF:65:D8:FE:6C (Unknown)
Nmap scan report for S190023240007 (192.168.66.88)
Host is up (0.090s latency).
MAC Address: 7C:DF:A1:D3:8C:5C (Espressif)
Nmap scan report for wlan0 (192.168.66.97)
Host is up (0.20s latency).
MAC Address: 10:D5:61:E2:18:E6 (Tuya Smart)
Nmap scan report for 192.168.66.179
Host is up (0.10s latency).
MAC Address: E4:AA:EC:8F:88:C9 (Tianjin Hualai Technology)
[...]
Nmap done: 256 IP addresses (7 hosts up) scanned in 2.64 seconds
```

Nmap offers a list scan with the option `-sL`. This scan only lists the targets to scan without actually scanning them. For example, `nmap -sL 192.168.0.1/24` will list the 256 targets that will be scanned.

> **Question:** What is the last IP address that will be scanned when your scan target is 192.168.0.1/27?

nmap -sL 192.168.0.1/27 answer 192.168.0.31

3. Port Scanning: Who Is Listening

Scanning TCP Ports: The easiest and most basic way to know whether a TCP port is open would be to attempt to telnet to the port. If you are inclined to scan with a Telnet client, try to establish a TCP connection with every target port.

Connect Scan: The connect scan can be triggered using -sT. It tries to complete the TCP three-way handshake with every target TCP port. If the TCP port turns out to be open and Nmap connects successfully, Nmap will tear down the established connection.

SYN Scan (Stealth): Unlike the connect scan, which tries to connect to the target TCP port, i.e., complete a three-way handshake, the SYN scan only executes the first step: it sends a TCP SYN packet. Consequently, the TCP three-way handshake is never completed. The advantage is that this is expected to lead to

fewer logs as the connection is never established, and hence, it is considered a relatively stealthy scan. You can select the SYN scan using the -sS flag.

Scanning UDP Ports: Although most services use TCP for communication, many use UDP. Examples include DNS, DHCP, NTP (Network Time Protocol), SNMP (Simple Network Management Protocol), and VoIP (Voice over IP). UDP does not require establishing a connection and tearing it down afterwards. Furthermore, it is very suitable for real-time communication, such as live broadcasts.

Nmap offers the option -sU to scan for UDP services. Because UDP is simpler than TCP, we expect the traffic to differ. The screenshot below shows several ICMP destination unreachable (port unreachable) responses as Nmap sends UDP packets to closed UDP ports.

Scanning UDP Ports: Although most services use TCP for communication, many use UDP. Examples include DNS, DHCP, NTP (Network Time Protocol), SNMP (Simple Network Management Protocol), and VoIP (Voice over IP). UDP does not require establishing a connection and tearing it down afterwards.

Nmap offers the option `-sU` to scan for UDP services. Because UDP is simpler than TCP, we expect the traffic to differ.

Limiting the Target Ports: Nmap scans the most common 1,000 ports by default. However, this might not be what you are looking for. Therefore, Nmap offers you a few more options.

- `F` is for Fast mode, which scans the 100 most common ports (instead of the default 1000).
- `p[range]` allows you to specify a range of ports to scan. For example, `p10-1024` scans from port 10 to port 1024, while `p-25` will scan all the ports between 1 and 25. Note that `p-` scans all the ports and is equivalent to `p1-65535` and is the best option if you want to be as thorough as possible.

4. Summary-1

Option	Explanation
`-sT`	TCP connect scan – complete three-way handshake
`-sS`	TCP SYN – only first step of the three-way handshake

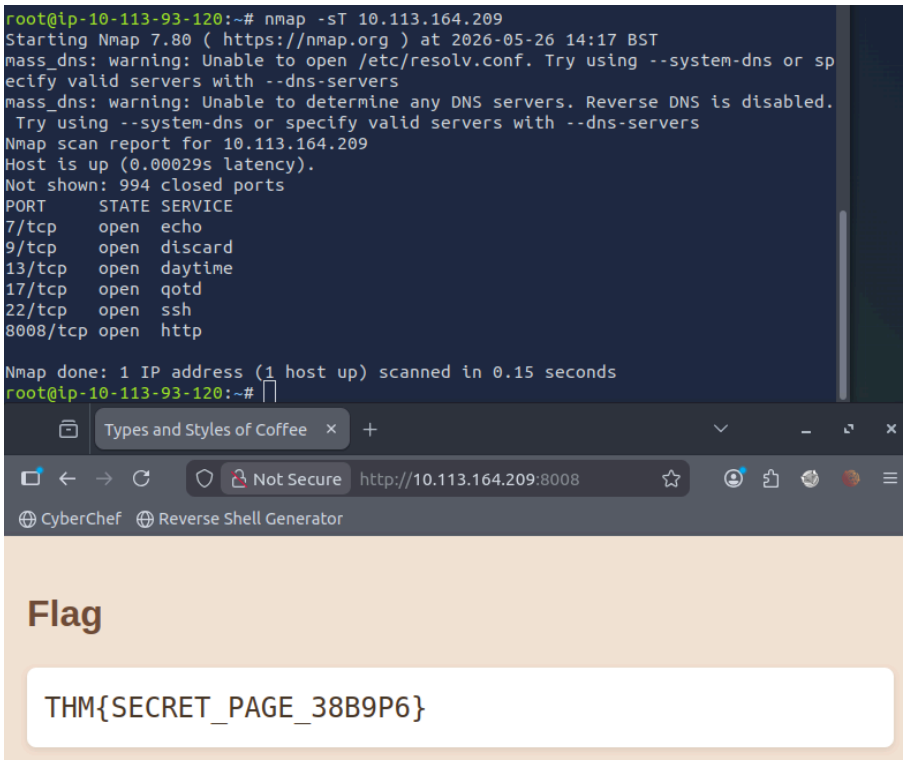
Option	Explanation
`-sU`	UDP scan
`-F`	Fast mode – scans the 100 most common ports
`-p[range]`	Specifies a range of port numbers – `-p-` scans all the ports

> Q. How many TCP ports are open on the target system at `10.113.164.209`?

A. 6 nmap -sT 10.113.164.209

> Q. Find the listening web server on `10.113.164.209` and access it with your browser. What is the flag that appears on its main page?

A. THM{SECRET_PAGE_38B9P6}



5. Version Detection: Extract More Information

OS Detection: You can enable OS detection by adding the -O option. As the name implies, the OS detection option triggers Nmap to rely on various indicators to make an educated guess about the target OS.

Service and Version Detection: You discovered several open ports and want to know what services are listening on them. `-sV` enables version detection. This is very convenient for gathering more information about your target with fewer keystrokes.

Forcing the Scan: When we run our port scan, such as using `-sS`, there is a possibility that the target host does not reply during the host discovery phase (e.g. a host doesn't reply to ICMP requests). Consequently, Nmap will mark this host as down and won't launch a port scan against it. We can ask Nmap to treat all hosts as online and port scan every host, including those that didn't respond during the host discovery phase. This choice can be triggered by adding the `-Pn` option.

6. Summary-2

Option	Explanation
`-O`	OS detection
`-sV`	Service and version detection
`-A`	OS detection, version detection, and other additions
`-Pn`	Scan hosts that appear to be down

> Q. What is the name and detected version of the web server running on 10.113.164.209?

lighttpd 1.4.74 (nmap -o 10.113.164.209)

7. Timing: How Fast is Fast

The table below should give you an idea, but you will get different results depending on the network setup and target system.

Timing	Total Duration
T0 (paranoid)	9.8 hours
T1 (sneaky)	27.53 minutes
T2 (polite)	40.56 seconds
T3 (normal)	0.15 seconds

Timing	Total Duration
T4 (aggressive)	0.13 seconds

A second helpful option is the number of parallel service probes. The number of parallel probes can be controlled with `--min-parallelism <numprobes>` and `--max-parallelism <numprobes>`. These options can be used to set a minimum and maximum on the number of TCP and UDP port probes active simultaneously for a host group. By default, `nmap` will automatically control the number of parallel probes. If the network is performing poorly, i.e., dropping packets, the number of parallel probes might fall to one; furthermore, if the network performs flawlessly, the number of parallel probes can reach several hundred.

A similar helpful option is the `--min-rate <number>` and `--max-rate <number>`. As the names indicate, they can control the minimum and maximum rates at which `nmap` sends packets. The rate is provided as the *number of packets per second*. It is worth mentioning that the specified rate applies to the whole scan and not to a single host.

The last option we will cover in this task is `--host-timeout <time>`. This option specifies the maximum time you are willing to wait, and it is suitable for slow hosts or hosts with slow network connections.

Option	Explanation
`-T<0-5>`	Timing template – paranoid (0), sneaky (1), polite (2), normal (3), aggressive (4), and insane (5)
`--min-parallelism <numprobes>` and `--max-parallelism <numprobes>`	Minimum and maximum number of parallel probes
`--min-rate <number>` and `--max-rate <number>`	Minimum and maximum rate (packets/second)
`--host-timeout`	Maximum amount of time to wait for a target host

> What is the non-numeric equivalent of `-T4`? Aggressive 0.13 seconds

8. Output: Controlling What You See

Verbosity: The best way to get more updates about what's happening is to enable verbose output by adding -v. Consider the following terminal output showing the network scan repeated twice. In the first case, we opted for the default output verbosity.

```
root@tryhackme:~# nmap -sS 192.168.139.1/24
Starting Nmap 7.92 ( https://nmap.org ) at 2024-08-13 18:57 EEST
Nmap scan report for 192.168.139.254
Host is up (0.000030s latency).
All 1000 scanned ports on 192.168.139.254 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: 00:50:56:E0:FC:AE (VMware)

Nmap scan report for g5000 (192.168.139.1)
Host is up (0.000010s latency).
Not shown: 999 closed tcp ports (reset)
PORT    STATE SERVICE
902/tcp open  iss-realsecure
```

Then, we repeated the same scan; however, the second time, we used the `-v` option for verbosity. The amount of details present below can be very useful, especially when you are learning about Nmap and exploring the different options. In the terminal output below, we can see how Nmap is moving from one stage to another: ARP ping scan, parallel DNS resolution, and finally, SYN stealth scan for every live host.

```
root@tryhackme:~# nmap 192.168.139.1/24 -v
Starting Nmap 7.92 ( https://nmap.org ) at 2024-08-13 19:01 EEST
Initiating ARP Ping Scan at 19:01
Scanning 255 hosts [1 port/host]
Completed ARP Ping Scan at 19:01, 7.94s elapsed (255 total hosts)
Initiating Parallel DNS resolution of 1 host. at 19:01
Completed Parallel DNS resolution of 1 host. at 19:02, 13.00s ela
Nmap scan report for 192.168.139.0 [host down]
Nmap scan report for 192.168.139.2 [host down]
```

Most likely, the `-v` option is more than enough for verbose output; however, if you are still unsatisfied, you can increase the verbosity level by adding another "v" such as `-vv` or even `-vvvv`. You can also specify the verbosity level directly, for

example, `-v2` and `-v4`. You can even increase the verbosity level by pressing “v” after the scan already started.

Debugging: If all this verbosity does not satisfy your needs, you must consider the `-d` for debugging-level output. Similarly, you can increase the debugging level by adding one or more “d” or by specifying the debugging level directly. The maximum level is `-d9`; before choosing that, make sure you are ready for thousands of information and debugging lines.

9. Saving Scan Report

Nmap gives us various formats. The three most useful are normal (human-friendly) output, XML output, and grepable output, in reference to the `grep` command. You can select the scan report format as follows:

- `oN <filename>` - Normal output
- `oX <filename>` - XML output
- `oG <filename>` - `grep`able output (useful for `grep` and `awk`)
- `oA <basename>` - Output in all major formats

In the terminal below, we can see an example of using the `-oA` option. It resulted in three reports with the extensions `nmap`, `xml`, and `gnmap` for normal, XML, and `grep`-able output.

```
root@tryhackme:~# nmap -sS 192.168.139.1 -oA gateway
Starting Nmap 7.92 ( https://nmap.org ) at 2024-08-13 19:35 EEST
Nmap scan report for g5000 (192.168.139.1)
Host is up (0.0000070s latency).
Not shown: 999 closed tcp ports (reset)
PORT    STATE SERVICE
902/tcp open  iss-realsecure

Nmap done: 1 IP address (1 host up) scanned in 0.13 seconds
# ls
gateway.gnmap  gateway.nmap  gateway.xml
```

> What option must you add to your nmap command to enable debugging? d

> What kind of scan will Nmap use if you run nmap 10.113.164.209 with local user privileges? Connect Scan

10. Summary-3

It is worth noting that it is best to run Nmap with sudo privileges so that we can make use of all its features. Running Nmap with local user privileges will still work; however, you should expect many features to be unavailable.

Option	Explanation
`-sL`	List scan – list targets without scanning
Host Discovery	
`-sn`	Ping scan – host discovery only
Port Scanning	
`-sT`	TCP connect scan – complete three-way handshake
`-sS`	TCP SYN – only first step of the three-way handshake
`-sU`	UDP Scan
`-F`	Fast mode – scans the 100 most common ports
`-p[range]`	Specifies a range of port numbers – `-p-` scans all the ports
`-Pn`	Treat all hosts as online – scan hosts that appear to be down
Service Detection	
`-O`	OS detection
`-sV`	Service version detection
`-A`	OS detection, version detection, and other additions
Timing	
`-T<0-5>`	Timing template – paranoid (0), sneaky (1), polite (2), normal (3), aggressive (4), and insane (5)
`--min-parallelism <numprobes>` and `--max-parallelism <numprobes>`	Minimum and maximum number of parallel probes

Option	Explanation
`--min-rate <number>` and `--max-rate <number>`	Minimum and maximum rate (packets/second)
`--host-timeout`	Maximum amount of time to wait for a target host
Real-time output	
`-v`	Verbosity level – for example, `-vv` and `-v4`
`-d`	Debugging level – for example `-d` and `-d9`
Report	
`-oN <filename>`	Normal output
`-oX <filename>`	XML output
`-oG <filename>`	`grep`-able output
`-oA <basename>`	Output in all major formats

2. Nmap Live Host Discovery

1. Subnetworks

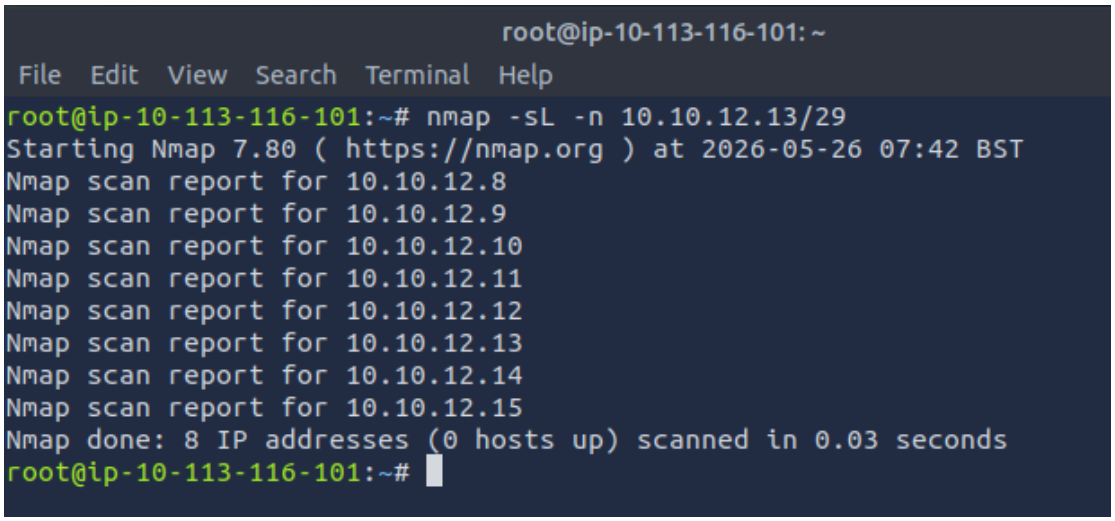
A subnet is a smaller logical division of a network. It is used to organize devices efficiently, improve security, and reduce network traffic. Subnetting helps manage IP addresses better by splitting a large network into smaller networks using a subnet mask or CIDR notation, such as `/24` or `/25`."

- Subnets with `/16`, which means that the subnet mask can be written as `255.255.0.0`. This subnet can accommodate around 65,000 hosts.
- Subnets with `/24`, which indicates that the subnet mask can be expressed as `255.255.255.0`. This subnet can have around 250 hosts.

2. Enumerating Targets

> Q. What is the first IP address Nmap would scan if you provided 10.10.12.13/29 as your target?

Ans. 10.10.12.8



> Q. How many IP addresses will Nmap scan if you provide the following range: 10.10.0-255.101-125?6400 (nmap -sL -n 10.10.0–255.101–125)

The `-n` flag in Nmap disables DNS resolution, meaning Nmap will not try to translate IP addresses into hostnames. This speeds up scans and reduces DNS-related network traffic.

3. Nmap Host Discovery Using ARP

Nmap follows the following approaches to discover live hosts:

1. When a privileged user tries to scan targets on a local network (Ethernet), Nmap uses ARP requests. A privileged user is `root` or a user who belongs to `sudoers` and can run `sudo`.
2. When a privileged user tries to scan targets outside the local network, Nmap uses ICMP echo requests, TCP ACK (Acknowledge) to port 80, TCP SYN (Synchronise) to port 443, and ICMP timestamp requests.
3. When an unprivileged user tries to scan targets outside the local network, Nmap resorts to a TCP 3-way handshake by sending SYN packets to ports 80 and 443.

> Q. How many hosts are found alive after scanning the CONNECTION_IP/24? 1

```
root@ip-10-113-116-101:~# nmap -sn 10.113.116.101/24
Starting Nmap 7.80 ( https://nmap.org ) at 2026-05-26 07:47 BST
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or sp
ecify valid servers with --dns-servers
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled.
 Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 10.113.116.101
Host is up.
Nmap done: 256 IP addresses (1 host up) scanned in 10.52 seconds
```

4. Nmap Host Discovery Using ICMP

ICMP stands for Internet Control Message Protocol. It is used in networking for error reporting and connectivity testing. Tools like ping and traceroute use ICMP to check whether hosts are reachable and to diagnose network issues.

A. ICMP echo request: It is to discover live hosts, add the option `-PE` option. (Remember to add `-sn` if you don't want to follow that with a port scan.) ICMP Echo Request is a network message used to test connectivity between devices. It is commonly used by the ping command to determine whether a host is reachable on the network.

Using the AB, we will scan the target's subnet using `nmap -PE -sn 10.200.6.0/24`. This scan will send ICMP echo packets to every IP address on the subnet. Again, we expect live hosts to reply; however, it is wise to keep in mind that many firewalls block ICMP. The output below shows the result of scanning the virtual machine's class C subnet using `sudo nmap -PE -sn 10.200.6.0/24` from the AttackBox. This command checks which devices are online in the `10.200.6.0/24` subnet by sending ICMP echo requests without performing a full port scan.

A /24 subnet means: 255.255.255.0=/24, So the scan range is typically: 10.200.6.1 → 10.200.6.254

```
root@ip-10-201-66-6:~# sudo nmap -PE -sn 10.200.6.0/24
sudo: unable to resolve host ip-10-201-66-6: Name or service not known
Starting Nmap 7.80 ( https://nmap.org ) at 2026-02-05 11:51 GMT
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or specify valid serve
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --syst
Nmap scan report for 10.200.6.1
Host is up (0.069s latency).
Nmap scan report for 10.200.6.50
Host is up (0.070s latency).
Nmap scan report for 10.200.6.250
Host is up (0.069s latency).
Nmap done: 256 IP addresses (3 hosts up) scanned in 3.38 seconds
```

B. ICMP Timestamp: Nmap uses a timestamp request (ICMP Type 13) and checks whether it will get a Timestamp reply (ICMP Type 14). Adding the `-PP` option tells Nmap to use ICMP timestamp requests. We run `nmap -PP -sn 10.200.6.0/24` to discover the online computers on the target machine subnet. The command performs host discovery on the `10.200.6.0/24` network using ICMP Timestamp Requests without scanning ports.

```
root@ip-10-201-66-6:~# nmap -PP -sn 10.200.6.0/24
Starting Nmap 7.80 ( https://nmap.org ) at 2026-02-05 12:10 GMT
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or specify valid serve
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --syst
Nmap scan report for 10.200.6.50
Host is up (0.069s latency).
Nmap scan report for 10.200.6.250
Host is up (0.069s latency).
Nmap done: 256 IP addresses (2 hosts up) scanned in 8.44 seconds
```

ICMP Timestamp Request is an ICMP message type used to query a device's system time. It can also be used in network scanning and diagnostics to identify active hosts.

C. ICMP Type 17: ICMP Type 17 is Address Mask Request, used by a host to request its subnet mask from a network device. It is largely obsolete today and replaced by DHCP. Similarly, Nmap uses address mask queries (ICMP Type 17) and checks whether it gets an address mask reply (ICMP Type 18). This scan can be enabled with the option `-PM`.

```
root@ip-10-201-66-6:~# nmap -PM -sn 10.200.6.0/24
Starting Nmap 7.80 ( https://nmap.org ) at 2026-02-05 12:15 GMT
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or specify valid serve
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --syst
Nmap done: 256 IP addresses (0 hosts up) scanned in 52.14 seconds
```

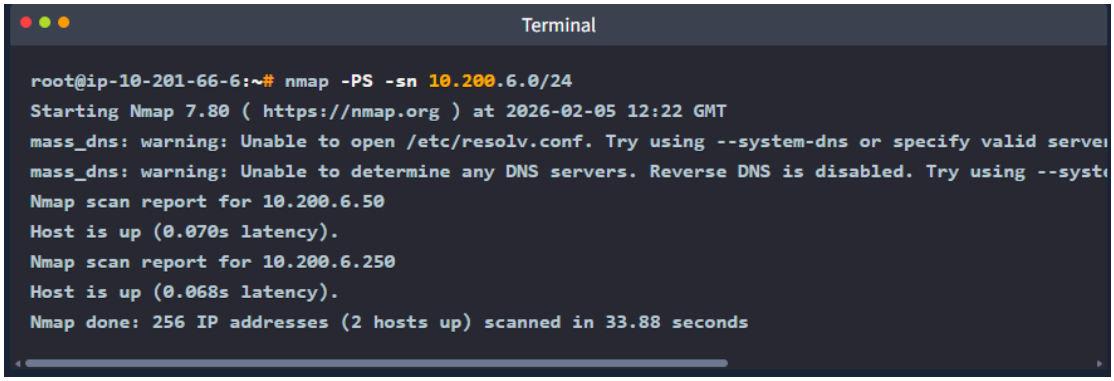
> Q1. What is the option required to tell Nmap to use ICMP Timestamp to discover live hosts? PP

> Q2. What is the option required to tell Nmap to use ICMP Address Mask to discover live hosts? PM

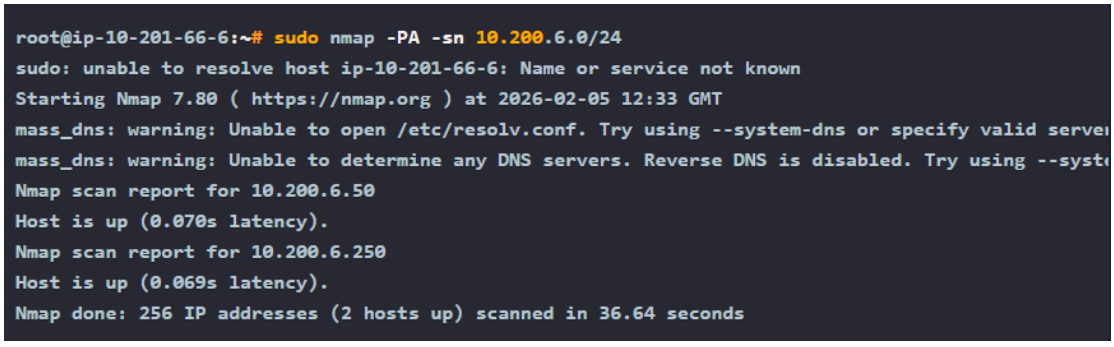
> Q3. What is the option required to tell Nmap to use ICMP Echo to discover live hosts? PE

5. Nmap Host Discovery Using TCP and UDP

A. TCP SYN Ping: We can send a packet with the SYN (Synchronise) flag set to TCP port 80 (80 by default) and wait for a response. An open port should reply with a SYN/ACK (Acknowledge); a closed port would result in an RST (Reset). In this case, we only check whether we receive a response to infer whether the host is up. We will run `nmap -PS -sn 10.200.6.0/24` to scan the target VM subnet.



B. TCP ACK Ping: As you have guessed, this sends a packet with an ACK flag set. You must run Nmap as a privileged user to accomplish this. If you try it as an unprivileged user, Nmap will attempt a 3-way handshake. By default, port 80 is used. The syntax is similar to TCP SYN ping. `-PA` should be followed by a port number, a port number range, a list, or a combination of them. For example, consider `-PA21`, `-PA21-25` and `-PA80,443,8080`. If no port is specified, port 80 will be used. In this example, we run `sudo nmap -PA -sn 10.200.6.0/24` to discover the online hosts on the target's subnet.



C. UDP Ping: Finally, we can use UDP to discover if the host is online. Unlike a TCP SYN ping, sending a UDP packet to an open port is not expected to elicit a reply.

However, if we send a UDP packet to a closed UDP port, we expect to get an ICMP port-unreachable packet; this indicates that the target system is up and available. The syntax to specify the ports is similar to that of TCP SYN ping and TCP ACK ping; Nmap uses `-PU` for UDP ping.

```
root@ip-10-201-66-6:~# sudo nmap -PU -sn 10.200.6.0/24
sudo: unable to resolve host ip-10-201-66-6: Name or service not known
Starting Nmap 7.80 ( https://nmap.org ) at 2026-02-05 12:38 GMT
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or specify valid serve
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --syst
Nmap scan report for 10.200.6.50
Host is up (0.070s latency).
Nmap scan report for 10.200.6.250
Host is up (0.069s latency).
Nmap done: 256 IP addresses (2 hosts up) scanned in 35.97 seconds
```

Masscan is a high-speed port scanner used to scan large networks very quickly. It is often used for reconnaissance because it can scan huge IP ranges in a short time, but it provides less detail compared to tools like Nmap.

On a side note, Masscan uses a similar approach to discover the available systems. However, to complete its network scan quickly, Masscan is quite aggressive in the rate at which it generates packets. The syntax is quite similar: -p can be followed by a port number, list, or range. Consider the following examples:

masscan 10.200.6.0/24 -p443
masscan 10.200.6.0/24 -p80,443
masscan 10.200.6.0/24 -p22-25

> Which TCP ping scan does not require a privileged account? TCP SYN Ping

> Which TCP ping scan requires a privileged account? TCP ACK Ping

> What option do you need to add to Nmap to run a TCP SYN ping scan on the telnet port? PS23

6. Using Reverse-DNS Lookup

Reverse DNS (rDNS) is the process of resolving an IP address to a hostname (the opposite of normal DNS). Instead of asking “What is the IP of example.com?”, you ask “What domain name is assigned to 10.200.6.15?”

In Nmap, using -R forces reverse lookups for all discovered hosts, while -n disables them. This helps identify system roles (e.g., mail.company.local, dc01.domain.com) and understand network structure during recon. However, rDNS records aren't always configured or accurate, so results may be missing or misleading. It can also slightly slow scans due to additional DNS queries. By default, Nmap will look up online hosts; however, you can use the option -R to query the DNS server even for offline hosts. If you want to use a specific DNS server, you can add the --dns-servers DNS_SERVER option.

We want Nmap to issue a reverse DNS lookup for all the possible hosts on a subnet, hoping to get some insights from the names. What option should we add? R (A reverse DNS lookup is the process of finding the domain name (hostname) associated with an IP address.)

7. Summary-4

You have learned how ARP, ICMP, TCP, and UDP can detect live hosts by completing this room.

Scan Type	Example Command
ARP Scan	sudo nmap -PR -sn 10.200.6.0/24
ICMP Echo Scan	sudo nmap -PE -sn 10.200.6.0/24
ICMP Timestamp Scan	sudo nmap -PP -sn 10.200.6.0/24
ICMP Address Mask Scan	sudo nmap -PM -sn 10.200.6.0/24
TCP SYN Ping Scan	sudo nmap -PS22,80,443 -sn 10.200.6.0/30
TCP ACK Ping Scan	sudo nmap -PA22,80,443 -sn 10.200.6.0/30
UDP Ping Scan	sudo nmap -PU53,161,162 -sn 10.200.6.0/30

Remember to add `-sn` if you are only interested in host discovery without port-scanning. Omitting `-sn` will let Nmap default to scanning live hosts for ports.

Option	Purpose
-n	no DNS lookup
-R	reverse-DNS lookup for all hosts
-sn	host discovery only

Knowing which hosts are online ensures accurate scoping and efficient follow-up scans. A host is a device on a network identified by an IP address, and a port is a logical endpoint on that host used to access specific services. Together, they define where network communication is directed.

3. Nmap Basic Port Scans

1. TCP and UDP Ports

At the risk of oversimplification, we can classify ports into two states:

1. An open port indicates that a service is listening on that port.
2. A closed port indicates that no service is listening on that port.

However, in practical situations, we need to consider the impact of firewalls. For instance, a port might be open, but a firewall might be blocking the packets. Therefore, Nmap considers the following six states:

1. An **open** port indicates that a service is listening on the specified port.
2. A **closed** port indicates that no service is listening on the specified port, although the port is accessible. By accessible, we mean that it is reachable and is not blocked by a firewall or other security appliances/programs.
3. **Filtered means that Nmap cannot determine whether the port is open or closed because it** is not accessible. This state is usually due to a firewall preventing Nmap from reaching that port. Nmap's packets may be blocked from reaching the port; alternatively, responses may be blocked from reaching Nmap's host.
4. **Unfiltered means that Nmap cannot determine whether the port is open or closed, even though** the port is accessible. This state is encountered when using an ACK scan `sA`.
5. **Open|Filtered**: This means that Nmap cannot determine whether the port is open or filtered.
6. **Closed|Filtered**: This means that Nmap cannot decide whether a port is closed or filtered.

> Which service uses UDP port 53 by default? DNS

> Which service uses TCP port 22 by default? SSH

> How many port states does Nmap consider? 6

> Which port state is the most interesting to discover as a pentester? Open

2. TCP Flags

the TCP header flags are:

1. **URG**: Urgent flag indicates that the urgent pointer field is significant. The urgent pointer indicates that the incoming data is urgent, and that a TCP segment with the URG flag set is processed immediately, without waiting for previously sent TCP segments.
2. **ACK**: Acknowledgement flag indicates that the acknowledgement number is significant. It is used to acknowledge the receipt of a TCP segment.
3. **PSH**: Push flag asking TCP to pass the data to the application promptly.
4. **RST**: The reset flag is used to reset the connection. Another device, such as a firewall, might send it to tear a TCP connection. This flag is also used when data is sent to a host, and there is no service on the receiving end to answer.
5. **SYN**: The synchronise flag is used to initiate a TCP 3-way handshake and synchronise sequence numbers with the other host. The sequence number should be set randomly during TCP connection establishment.
6. **FIN**: The sender has no more data to send.

What 3 letters represent the Reset flag? RST
Which flag needs to be set when you initiate a TCP connection (first packet of TCP 3-way handshake)? SYN

3. TCP Connect Scan

TCP connect scan works by completing the TCP 3-way handshake. In standard TCP connection establishment, the client sends a TCP packet with the SYN flag set, and the server responds with SYN/ACK if the port is open; finally, the client completes the 3-way handshake by sending an ACK. whether the TCP port

is open, not in establishing a TCP connection. Hence, the connection is torn as soon as its state is confirmed by sending a RST/ACK. You can choose to run a TCP connect scan using `-sT`. It is important to note that if you are not a privileged user (root or sudoer), a TCP connect scan is the only possible option to discover open TCP ports. To illustrate the `-sT` (TCP connect scan), Run the following command in the AB to get a detailed list of the open ports.

```
root@ip-10-201-98-13:~# nmap -sT MACHINE_IP
Starting Nmap 7.80 ( https://nmap.org ) at 2026-02-10 12:16 GMT
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or specify valid serve
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --syst
Nmap scan report for MACHINE_IP
Host is up (0.070s latency).
Not shown: 996 closed ports
PORT STATE SERVICE
21/tcp xxxx ftp
22/tcp open ssh
53/tcp open xxxxxx
80/tcp open http

Nmap done: 1 IP address (1 host up) scanned in 1.25 seconds
```

Note that we can use `-F` to enable fast mode and decrease the number of scanned ports from 1000 to 100 most common ports. It is worth mentioning that the `-r` option can also be added to scan the ports in consecutive order instead of random order. This option is useful for testing whether ports open consistently, for instance, when a target boots up.

> What is the state of the FTP service running on port 21? open

> What is Nmap’s guess about the service running on port 53? domain

4. TCP SYN Scan

Unprivileged users are limited to the connect scan. However, the default scan mode is a SYN scan, and it requires a privileged (root or sudo) user to run. SYN scan does not need to complete the TCP 3-way handshake; instead, it tears down the connection after receiving a response from the server. Because we didn’t establish a TCP connection, the scan is less likely to be logged. We can select this scan type by using the -sS option. The figure below shows how the TCP SYN scan works without completing the TCP 3-way handshake.we can see TCP connect

scan `-sT` traffic. Any open TCP port will require Nmap to complete the TCP 3-way handshake before closing the connection. In the lower half of the following figure, we see how a SYN scan `-sS` does not need to complete the TCP 3-way handshake; instead, Nmap sends an RST packet once a SYN/ACK packet is received.

```
root@ip-10-201-98-13:~# nmap -sS 10.10.105.229
Starting Nmap 7.80 ( https://nmap.org ) at 2026-02-10 12:08 GMT
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or specify valid serve
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --syst
Nmap scan report for 10.10.105.229
Host is up (0.070s latency).
Not shown: 996 closed ports
PORT STATE SERVICE
21/tcp open ftp
22/tcp open ssh
53/tcp open domain
80/tcp open http

Nmap done: 1 IP address (1 host up) scanned in 1.36 seconds
```

> After launching a TCP SYN scan, how many SYN-ACK packets are successfully received in AttackBox? 4

> How many ports are open on the target machine? 4

5. UDP Scan

UDP is a connectionless protocol; hence, it does not require a handshake for connection establishment. If a UDP packet is sent to a closed port, an ICMP port unreachable error (type 3, code 3) is returned. You can select UDP scan using the `-sU` option; moreover, you can combine it with another TCP scan.

From the AB, use the following command to perform a UDP scan of the top 10 ports on the target machine:



> What is the state of port number 161 over UDP in the target machine? closed

> What is the service name according to Nmap on port 161? snmp

6. Fine-Tuning Scope and Performance

You can specify the ports you want to scan instead of the default 1000 ports. Specifying the ports is intuitive by now.

- port list: `p22,80,443` will scan ports 22, 80 and 443.
- port range: `p1-1023` will scan all ports between 1 and 1023 inclusive, while `p20-25` will scan ports between 20 and 25 inclusive.

You can request the scan of all ports by using `-p-`, which will scan all 65535 ports. If you want to scan the most common 100 ports, add `-F`. Using `--top-ports 10` will check the ten most common ports. You can control the scan timing using `-T<0-5>`. `-T0` is the slowest (paranoid), while `-T5` is the fastest. According to the Nmap manual page, there are six templates:

- paranoid (0)
- sneaky (1)

- polite (2)
- normal (3)
- aggressive (4)
- insane (5)

To avoid IDS alerts, you might consider `-T0` or `-T1`. For instance, `-T0` scans one port at a time and waits 5 minutes between sending each probe, so you can guess how long scanning one target would take to finish. If you don't specify any timing, Nmap uses normal `-T3`. Note that `-T5` is the most aggressive in terms of speed; however, this can affect the accuracy of the scan results due to the increased likelihood of packet loss. Note that `-T4` is often used during CTFs and when learning to scan on practice targets, whereas `-T1` is often used during real engagements where stealth is more important. Alternatively, you can choose to control the packet rate using `--min-rate <number>` and `--max-rate <number>`. For example, `--max-rate 10` or `--max-rate=10` ensures that your scanner is not sending more than ten packets per second.

Moreover, you can control probing parallelisation using `--min-parallelism <numprobes>` and `--max-parallelism <numprobes>`. Nmap probes targets to discover which hosts are live and which ports are open; the probing parallelisation parameter specifies the number of such probes that can run in parallel. For instance, `--min-parallelism=512` pushes Nmap to maintain at least 512 probes in parallel; these 512 probes are related to host discovery and open ports.

> What is the option to scan all the TCP ports between 5000 and 5500? -p 5000-5500

> How can you ensure that Nmap will run at least 64 probes in parallel? --min-parallelism 64

> What option would you add to make Nmap very slow and paranoid? -T0

7. Summary-5

This room covered three types of scans.

Port Scan Type	Example Command
TCP Connect Scan	nmap -sT MACHINE_IP
TCP SYN Scan	sudo nmap -sS MACHINE_IP
UDP Scan	sudo nmap -sU MACHINE_IP

These scan types should get you started discovering running TCP and UDP services on a target host.

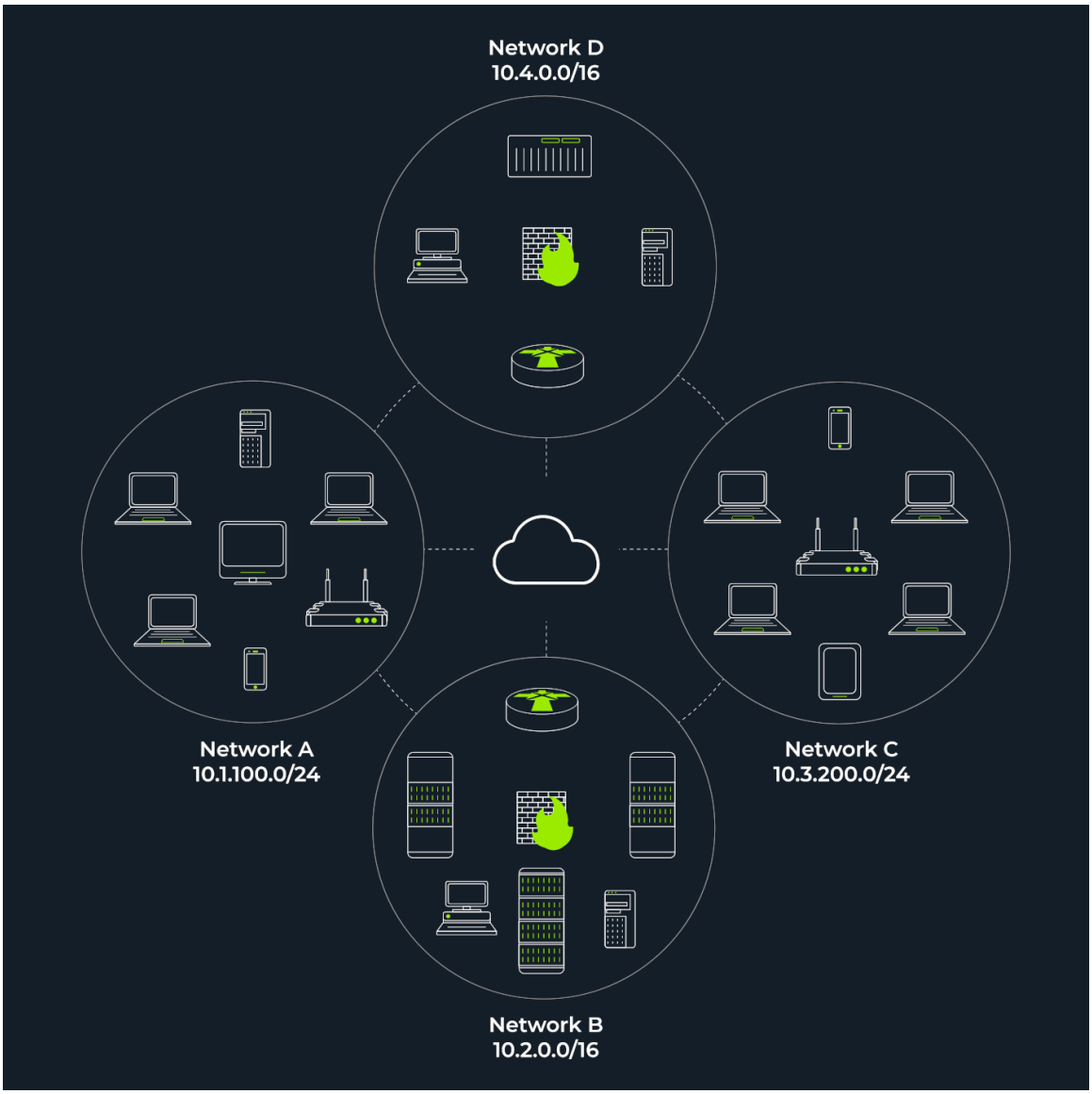
Option	Purpose
-p-	all ports
-p1-1023	scan ports 1 to 1023
-F	100 most common ports
-r	scan ports in consecutive order
-T<0-5>	-T0 being the slowest and T5 the fastest
--max-rate 50	rate <= 50 packets/sec
--min-rate 15	rate >= 15 packets/sec
--min-parallelism 100	at least 100 probes in parallel

4. Nmap Advanced Port Scans

1. Introduction

A *network segment* is a group of computers connected using a shared medium. For instance, the medium can be an Ethernet switch or a Wi-Fi access point. In an IP network, a *subnetwork* is usually equivalent to one or more network segments connected to the same router. The network segment refers to a physical connection, while a subnetwork refers to a logical connection.

In the following network diagram, we have four network segments or subnetworks. Generally speaking, your system would be connected to one of these network segments/subnetworks. A subnetwork, or simply a subnet, has its own IP address range and is connected to a more extensive network via a router. Additionally, a firewall may be present between network segments, enforcing security policies on the traffic that passes between them.



The figure above shows two types of subnets:

- Subnets with `/16`, which means that the subnet mask can be written as `255.255.0.0`. This subnet can accommodate around 65,000 hosts.
- Subnets with `/24`, which indicates that the subnet mask can be expressed as `255.255.255.0`. This subnet can have around 250 hosts.

As part of active reconnaissance, we want to discover more information about a group of hosts or about a subnet. If you are on the same subnet, you would expect your scanner to use ARP Address Resolution Protocol (ARP) queries to discover live hosts. An ARP query aims to obtain the hardware address (MAC address) so

that communication at the link layer is possible; however, it can also indicate that the host is online. (We revisit link-layer in Task 4.)

If you are in **Network A**, you can use ARP only to discover the devices within that subnet (10.1.100.0/24). Suppose you are connected to a subnet different from the subnet of the target system(s). In that case, all packets generated by your scanner will be routed via the default gateway (router) to reach systems on another subnet; however, ARP queries won't be routed and therefore cannot cross the subnet router. ARP is a link-layer protocol, and ARP packets are bound to their subnet.

2. TCP Null Scan, FIN Scan, and Xmas Scan

Null Scan: The null scan does not set any flag; all six flag bits are set to zero. You can choose this scan using the `-sN` option. A TCP packet with no flags set will not trigger any response when it reaches an open port, as shown in the figure below. Therefore, from Nmap's perspective, a lack of reply in a null scan indicates that either the port is open or a firewall is blocking the packet.



Case: TCP Port is open.

However, we expect the target server to respond with an RST packet if the port is closed. Consequently, we can use the lack of RST response to determine which ports are not closed: open or filtered.



Case: TCP Port is closed.

Below is an example of a null scan against a Linux server. The null scan we conducted successfully identified the nine open ports on the target system. Because the null scan relies on the lack of a response to infer that a port is open, it cannot conclusively indicate that these ports are open; it is possible that they are not responding due to a firewall rule. In the AB, enter the following command in the terminal:

```
root@ip-10-10-166-81:~# sudo nmap -sN MACHINE_IP
sudo: unable to resolve host ip-10-10-166-81: Name or service
not known
Starting Nmap 7.80 ( https://nmap.org ) at 2026-02-17 06:52 G
MT
mass_dns: warning: Unable to open /etc/resolv.conf. Try using
--system-dns or specify valid servers with --dns-servers
mass_dns: warning: Unable to determine any DNS servers. Rever
se DNS is disabled. Try using --system-dns or specify valid s
ervers with --dns-servers
Nmap scan report for 10.201.89.221
Host is up (0.070s latency).
Not shown: 991 closed ports
PORT STATE SERVICE
22/tcp open|filtered ssh
25/tcp open|filtered smtp
80/tcp open|filtered http
```

```
110/tcp open|filtered pop3
111/tcp open|filtered rpcbind
143/tcp open|filtered imap
993/tcp open|filtered imaps
995/tcp open|filtered pop3s
5000/tcp open|filtered upnp

Nmap done: 1 IP address (1 host up) scanned in 2.43 seconds
```

Note that many Nmap options require root privileges. Unless you are running Nmap as root, you need to use `sudo` as in the example above using the `-sN` option.

FIN Scan: The FIN scan sends a TCP packet with the FIN flag set. You can choose this scan type using the `-sF` option. Similarly, no response will be sent if the TCP port is open. Again, Nmap cannot be sure whether the port is open or whether a firewall is blocking traffic on this TCP port.



Case: TCP Port is open.

However, the target system should respond with an RST if the port is closed. Consequently, we will be able to identify which ports are closed and use this knowledge to infer which are open or filtered. It's worth noting that some firewalls will 'silently' drop the traffic without sending an RST.



Case: TCP Port is closed.

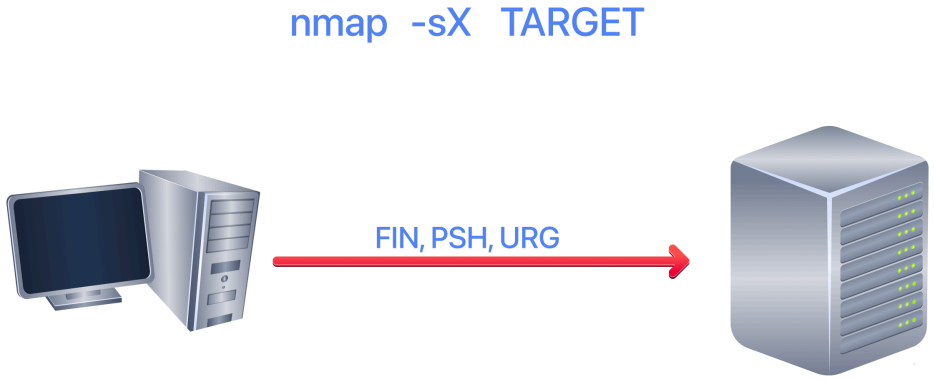
Below is an example of a FIN scan against a Linux server. The result is quite similar to that obtained earlier using a null scan. In the AB, enter the following command:

```
root@ip-10-10-166-81:~# sudo nmap -sF MACHINE_IP
sudo: unable to resolve host ip-10-10-166-81: Name or service
not known
Starting Nmap 7.80 ( https://nmap.org ) at 2026-02-17 07:10 G
MT
mass_dns: warning: Unable to open /etc/resolv.conf. Try using
--system-dns or specify valid servers with --dns-servers
mass_dns: warning: Unable to determine any DNS servers. Rever
se DNS is disabled. Try using --system-dns or specify valid s
ervers with --dns-servers
Nmap scan report for 10.201.89.221
Host is up (0.072s latency).
Not shown: 991 closed ports
PORT STATE SERVICE
22/tcp open|filtered ssh
25/tcp open|filtered smtp
80/tcp open|filtered http
110/tcp open|filtered pop3
111/tcp open|filtered rpcbind
143/tcp open|filtered imap
```

```
993/tcp open|filtered imaps
995/tcp open|filtered pop3s
5000/tcp open|filtered upnp

Nmap done: 1 IP address (1 host up) scanned in 2.39 seconds
```

Xmas Scan: The Xmas scan gets its name from the Christmas tree lights. An Xmas scan sets the FIN, PSH, and URG flags simultaneously. You can select the Xmas scan with the option `-sX`. As with the Null and FIN scans, receiving an RST packet indicates that the port is closed. Otherwise, it will be reported as open|filtered. The following two figures show the cases when the TCP port is open and when it is closed.



Case: TCP Port is open.

In case the port is closed.



Case: TCP Port is closed.

The console output below shows an example of a Xmas scan against a Linux server. The results are pretty similar to those of the null and FIN scans. In the AB, enter the following command:

```
root@ip-10-10-166-81:~# sudo nmap -sX MACHINE_IP
sudo: unable to resolve host ip-10-10-166-81: Name or service
not known
Starting Nmap 7.80 ( https://nmap.org ) at 2026-02-17 07:13 G
MT
mass_dns: warning: Unable to open /etc/resolv.conf. Try using
--system-dns or specify valid servers with --dns-servers
mass_dns: warning: Unable to determine any DNS servers. Rever
se DNS is disabled. Try using --system-dns or specify valid s
ervers with --dns-servers
Nmap scan report for 10.201.89.221
Host is up (0.073s latency).
Not shown: 991 closed ports
PORT STATE SERVICE
22/tcp open|filtered ssh
25/tcp open|filtered smtp
80/tcp open|filtered http
110/tcp open|filtered pop3
111/tcp open|filtered rpcbind
143/tcp open|filtered imap
```

```
993/tcp open|filtered imaps
995/tcp open|filtered pop3s
5000/tcp open|filtered upnp

Nmap done: 1 IP address (1 host up) scanned in 2.40 seconds
```

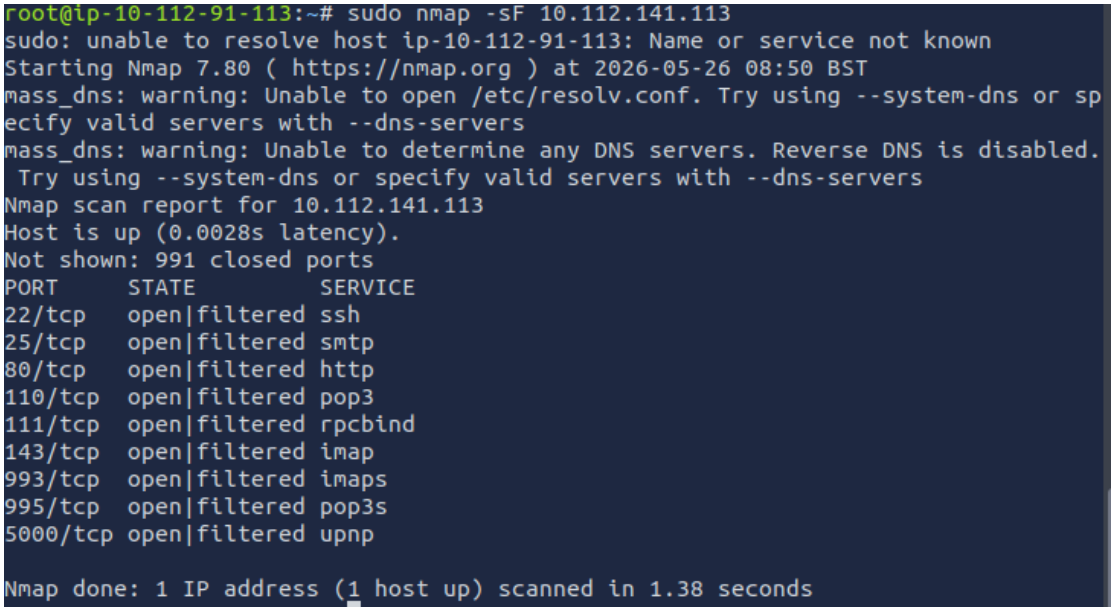
> In a null scan, how many flags are set to 1? 0

> In a FIN scan, how many flags are set to 1? 1

> In a Xmas scan, how many flags are set to 1? 3

> Launch a FIN scan against the target VM. How many ports appear as open|filtered? 9

> Repeat your scan launching a null scan against the target VM. How many ports appear as open|filtered? 9



```
root@ip-10-112-91-113:~# sudo nmap -sN 10.112.141.113
sudo: unable to resolve host ip-10-112-91-113: Name or service not known
Starting Nmap 7.80 ( https://nmap.org ) at 2026-05-26 08:51 BST
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or sp
ecify valid servers with --dns-servers
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled.
 Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 10.112.141.113
Host is up (0.00071s latency).
Not shown: 991 closed ports
PORT     STATE         SERVICE
22/tcp   open|filtered ssh
25/tcp   open|filtered smtp
80/tcp   open|filtered http
110/tcp  open|filtered pop3
111/tcp  open|filtered rpcbind
143/tcp  open|filtered imap
993/tcp  open|filtered imaps
995/tcp  open|filtered pop3s
5000/tcp open|filtered upnp

Nmap done: 1 IP address (1 host up) scanned in 1.38 seconds
```

3. TCP Maimon Scan

The target should send an RST packet as a response. However, certain BSD-derived systems drop the packet if it is an open port exposing the open ports. This scan won't work on most targets encountered in modern networks; however, we include it in this room to better understand the port scanning mechanism and the hacking mindset. To select this scan type, use the `-sM` option. Most target systems respond with an RST packet regardless of whether the TCP port is open. In such a case, we won't be able to discover the open ports. The figure below shows the expected behaviour for both open and closed TCP ports.



Case: TCP Port is open or closed.
Certain systems drop the packet if the port is open.

The console output below is an example of a TCP Maimon scan against a Linux server. As mentioned, because open and closed ports behave the same way, the Maimon scan could not detect any open ports on the target system.

```
root@ip-10-10-166-81:~# sudo nmap -sM 10.201.89.221
sudo: unable to resolve host ip-10-10-166-81: Name or service
not known
Starting Nmap 7.80 ( https://nmap.org ) at 2026-02-17 07:17 G
MT
mass_dns: warning: Unable to open /etc/resolv.conf. Try using
--system-dns or specify valid servers with --dns-servers
mass_dns: warning: Unable to determine any DNS servers. Rever
se DNS is disabled. Try using --system-dns or specify valid s
ervers with --dns-servers
Nmap scan report for 10.201.89.221
Host is up (0.075s latency).
All 1000 scanned ports on 10.201.89.221 are closed

Nmap done: 1 IP address (1 host up) scanned in 1.38 seconds
```

This type of scan is not the first scan one would pick to discover a system; however, it is important to know about it, as you don't know when it could come in

handy.

> In the Maimon scan, how many flags are set? 2

4. TCP ACK, Window, and Custom Scan

TCP ACK Scan: Let's start with the TCP ACK scan. As the name implies, an ACK scan will send a TCP packet with the ACK flag set. Use the `-sA` option to choose this scan. As shown in the figure below, the target would respond to the ACK with RST regardless of the port's state. This behaviour occurs because a TCP packet with the ACK flag set should be sent only in response to a received TCP packet to acknowledge receipt of data, unlike in our case. Hence, this scan won't tell us whether the target port is open in a simple setup.



Case: TCP Port is open or closed.

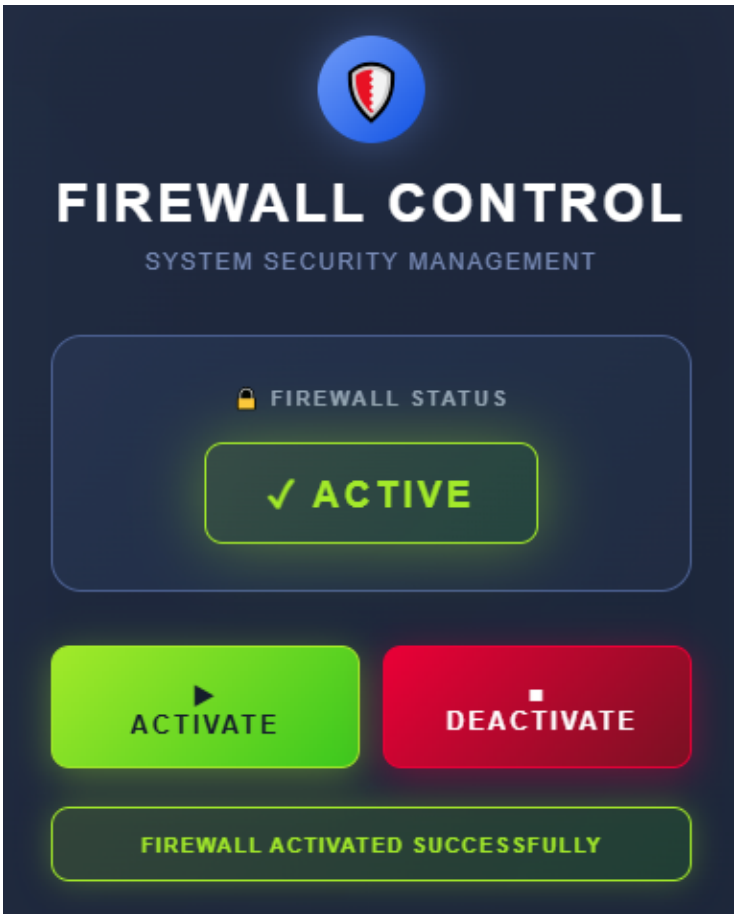
In the following example, we will scan the target VM before installing a firewall on it. As expected, we couldn't learn which ports were open.

```
root@ip-10-10-166-81:~# sudo nmap -sA MACHINE_IP
sudo: unable to resolve host ip-10-10-166-81: Name or service
not known
Starting Nmap 7.80 ( https://nmap.org ) at 2026-02-17 07:20 G
MT
mass_dns: warning: Unable to open /etc/resolv.conf. Try using
--system-dns or specify valid servers with --dns-servers
```

```
mass_dns: warning: Unable to determine any DNS servers. Rever
se DNS is disabled. Try using --system-dns or specify valid s
ervers with --dns-servers
Nmap scan report for 10.201.89.221
Host is up (0.074s latency).
All 1000 scanned ports on 10.201.89.221 are unfiltered

Nmap done: 1 IP address (1 host up) scanned in 1.38 seconds
```

This kind of scan would be helpful if a firewall were in front of the target. Consequently, based on which ACK packets resulted in responses, you will learn which ports were not blocked by the firewall. In other words, this type of scan is better suited to discovering firewall rule sets and configurations. Visit the URL `http://MACHINE_IP:5000` to activate the firewall, and we will repeat the scan.



This time, we received some interesting results. As shown in the console output below, the firewall is blocking all other ports except these five.

```
root@ip-10-10-166-81:~# sudo nmap -sA MACHINE_IP
sudo: unable to resolve host ip-10-10-166-81: Name or service
not known
Starting Nmap 7.80 ( https://nmap.org ) at 2026-02-17 07:26 G
MT
mass_dns: warning: Unable to open /etc/resolv.conf. Try using
--system-dns or specify valid servers with --dns-servers
mass_dns: warning: Unable to determine any DNS servers. Rever
se DNS is disabled. Try using --system-dns or specify valid s
ervers with --dns-servers
Nmap scan report for 10.201.89.221
Host is up (0.070s latency).
Not shown: 995 filtered ports
PORT STATE SERVICE
22/tcp unfiltered ssh
25/tcp unfiltered smtp
80/tcp unfiltered http
443/tcp unfiltered https
5000/tcp unfiltered upnp

Nmap done: 1 IP address (1 host up) scanned in 5.69 seconds
```

Window Scan: Another similar scan is the TCP window scan. The TCP window scan is almost identical to the ACK scan; however, it examines the TCP Window field of the RST packets returned. On specific systems, this can reveal that the port is open. You can select this scan type with the option `-sW`. As shown in the figure below, we expect to get an RST packet in reply to our “uninvited” ACK packets, regardless of whether the port is open or closed.



Case: TCP Port is open or closed.

Similarly, launching a TCP window scan against a Linux system without a firewall will not yield much information. As shown in the console output below, the results of the window scan against a Linux server with no firewall didn't provide any additional information beyond the ACK scan executed earlier.

```
root@ip-10-10-166-81:~# sudo nmap -sW MACHINE_IP
sudo: unable to resolve host ip-10-10-166-81: Name or service
not known
Starting Nmap 7.80 ( https://nmap.org ) at 2026-02-17 08:11 G
MT
mass_dns: warning: Unable to open /etc/resolv.conf. Try using
--system-dns or specify valid servers with --dns-servers
mass_dns: warning: Unable to determine any DNS servers. Rever
se DNS is disabled. Try using --system-dns or specify valid s
ervers with --dns-servers
Nmap scan report for 10.201.89.221
Host is up (0.072s latency).
All 1000 scanned ports on 10.201.89.221 are closed

Nmap done: 1 IP address (1 host up) scanned in 1.38 seconds
```

However, as you would expect, if we repeat our TCP window scan against a server behind a firewall, we expect to get more satisfying results. In the console output

shown below, the TCP window scan identified five ports as closed. (This is in contrast with the ACK scan, which labelled the same five ports as unfiltered.) Although we know that these five ports are not closed, we realise they responded differently, indicating that the firewall does not block them.

```
root@ip-10-10-166-81:~# sudo nmap -s MACHINE_IP
sudo: unable to resolve host ip-10-10-166-81: Name or service
not known
Starting Nmap 7.80 ( https://nmap.org ) at 2026-02-17 08:13 G
MT
mass_dns: warning: Unable to open /etc/resolv.conf. Try using
--system-dns or specify valid servers with --dns-servers
mass_dns: warning: Unable to determine any DNS servers. Rever
se DNS is disabled. Try using --system-dns or specify valid s
ervers with --dns-servers
Nmap scan report for 10.201.89.221
Host is up (0.067s latency).
Not shown: 995 filtered ports
PORT STATE SERVICE
22/tcp closed ssh
25/tcp closed smtp
80/tcp closed http
443/tcp closed https
5000/tcp closed upnp

Nmap done: 1 IP address (1 host up) scanned in 5.08 seconds
```

Custom Scan: If you want to experiment with a new TCP flag combination beyond the built-in TCP scan types, you can do so using `--scanflags`. For instance, if you want to set SYN, RST, and FIN simultaneously, you can do so using `--scanflags RSTSYNFIN`. As shown in the figure below, if you develop your own custom scan, you need to understand how the different ports will behave to correctly interpret the results in different scenarios.

nmap - - scanflags CUSTOM_FLAGS TARGET



Case: Choose which flags to set.
--scanflags URGACKPSHRSTSYNFIN sets all flags.

Finally, it is essential to note that the ACK and window scans were highly effective in helping us map the firewall rules. However, it is vital to remember that just because a firewall is not blocking a specific port, it does not necessarily mean that a service is listening on that port. For example, the firewall rules may need to be updated to reflect recent service changes. Hence, ACK and window scans are exposing the firewall rules, not the services.

> In TCP Window scan, how many flags are set? 1

> You decided to experiment with a custom TCP scan that has the reset flag set. What would you add after --scanflags? RST

> Launch an ACK scan against the target VM with the firewall enabled. How many ports appear unfiltered? 5

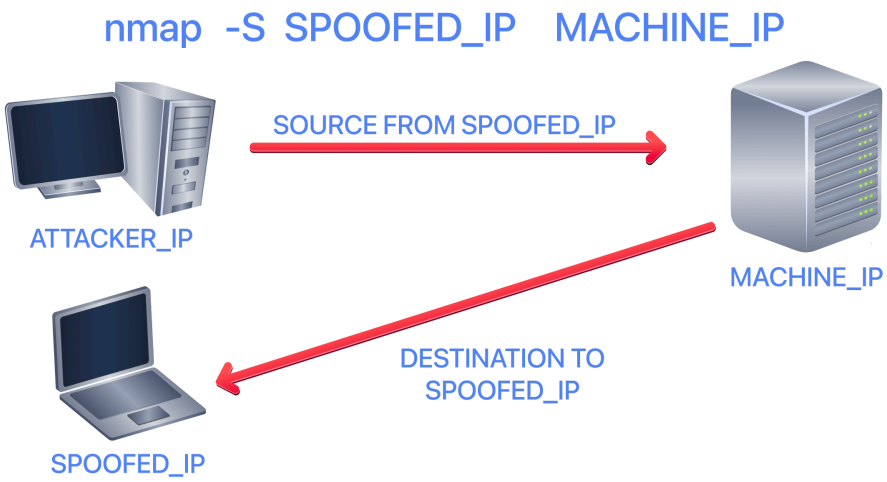
> What is the new port number that appeared? To determine the new port you need to compare the scan results of Task 2 to the ones of this task.443

> Is there any service behind the newly discovered port number? yea

```
root@ip-10-112-91-113:~# sudo nmap -sA 10.112.141.113
sudo: unable to resolve host ip-10-112-91-113: Name or service not known
Starting Nmap 7.80 ( https://nmap.org ) at 2026-05-26 09:02 BST
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or sp
ecify valid servers with --dns-servers
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled.
 Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 10.112.141.113
Host is up (0.00071s latency).
Not shown: 995 filtered ports
PORT     STATE      SERVICE
22/tcp   unfiltered ssh
25/tcp   unfiltered smtp
80/tcp   unfiltered http
443/tcp  unfiltered https
5000/tcp unfiltered upnp
```

5. Spoofing and Decoys

The following figure shows the attacker launching the command `nmap -S SPOOFED_IP MACHINE_IP`. Consequently, Nmap will craft all the packets using the provided source IP address `SPOOFED_IP`. The target machine will respond to the incoming packets, sending the replies to the destination IP address `SPOOFED_IP`. For this scan to work and give accurate results, the attacker needs to monitor the network traffic to analyse the replies.



Using SPOOFED_IP as the source IP address for the scan.

In brief, scanning with a spoofed IP address is three steps:

1. The attacker sends a packet with a spoofed source IP address to the target machine.
2. The target machine replies to the spoofed IP address as the destination.
3. The attacker captures replies to identify open ports.

In general, you expect to specify the network interface using `-e` and to explicitly disable ping scan `-Pn`. Therefore, instead of `nmap -S SPOOFED_IP MACHINE_IP`, you will need to issue `nmap -e NET_INTERFACE -Pn -S SPOOFED_IP MACHINE_IP` to tell Nmap explicitly which network interface to use and not to expect to receive a ping reply. It is worth repeating that this scan will be useless if the attacker's system cannot monitor the network for responses.

When you are on the same subnet as the target machine, you can spoof your MAC address as well. You can specify the source MAC address using `--spoof-mac SPOOFED_MAC`. This address spoofing is only possible if the attacker and the target machine are on the same Ethernet (802.3) network or the same WiFi (802.11).

Spoofing only works in a minimal number of cases where certain conditions are met. Therefore, the attacker might resort to decoys to make it harder to pinpoint. The concept is simple: make the scan appear to originate from many IP addresses so that the attacker’s IP address is lost among them. As shown in the figure below, the scan of the target machine will appear to come from 3 different sources, and consequently, the replies will go to the decoys as well.

You can launch a decoy scan by specifying a specific or random IP address after `-D`. For example, `nmap -D 10.10.0.1,10.10.0.2,ME MACHINE_IP` will make the scan of MACHINE_IP appear as coming from the IP addresses 10.10.0.1, 10.10.0.2, and then `ME` to indicate that your IP address should appear in the third order. Another example command would be `nmap -D 10.10.0.1,10.10.0.2,RND,RND,ME MACHINE_IP`, where the third and fourth source IP addresses are assigned randomly, while the fifth source is going to be the attacker’s IP address. In other words, each time you execute the latter command, you would expect two new random IP addresses to be the third and fourth decoy sources.

> What do you need to add to the command sudo nmap MACHINE_IP to make the scan appear as if coming from the source IP address 10.10.10.11 instead of your IP address?

S 10.10.10.11

> What do you need to add to the command sudo nmap MACHINE_IP to make the scan appear as if coming from the source IP addresses 10.10.20.21 and 10.10.20.28 in addition to your IP address?

D 10.10.20.21,10.10.20.28,ME

6. Fragmented Packets

Firewall: A firewall is a piece of software or hardware that either permits or blocks packets. It functions based on firewall rules, summarised as blocking all traffic with exceptions or allowing all traffic with exceptions. For instance, you might block all traffic to your server except that coming to your web server. A traditional firewall inspects at least the IP and transport layer headers. A more sophisticated firewall would also try to examine the data carried by the transport layer.

IDS: An Intrusion Detection System (IDS) inspects network packets for select behavioural patterns or specific content signatures. It raises an alert whenever a malicious rule is met. In addition to the IP and transport layer headers, an IDS would inspect the transport layer data and check whether it matches any malicious patterns. How can you make it less likely for a traditional firewall/IDS to detect your Nmap activity? It is not easy to answer this; however, depending on the type of firewall/IDS, you might benefit from dividing the packet into smaller packets.

Fragmented Packets: Nmap provides the option `-f` to fragment packets. Once chosen, the IP data will be divided into 8 bytes or fewer. Adding another `-f` (`-f -f` or `-ff`) will split the data into 16 byte-fragments instead of 8. You can change the default value by using the `--mtu`; however, you should always choose a multiple of 8. To properly understand fragmentation, we need to examine the IP header shown in the figure below. It might look complicated at first, but we notice that we know most of its fields. In particular, notice that the source address occupies 32 bits (4 bytes) on the fourth row, while the destination address occupies another 4 bytes on the fifth row. The data that we will fragment across multiple packets is highlighted in red. To aid reassembly on the recipient side, IP

uses the identification (ID) and fragment offset, shown in the second row of the figure below.

Note that if you added `-ff` (or `-f -f`), the data will be fragmented into multiples of 16. In other words, the 24 bytes of the TCP header, in this case, would be divided over two IP fragments, the first containing 16 bytes and the second containing 8 bytes of the TCP header. On the other hand, if you prefer to increase the size of your packets to make them look innocuous, you can use the option `--data-length NUM`, where num specifies the number of bytes you want to append to your packets.

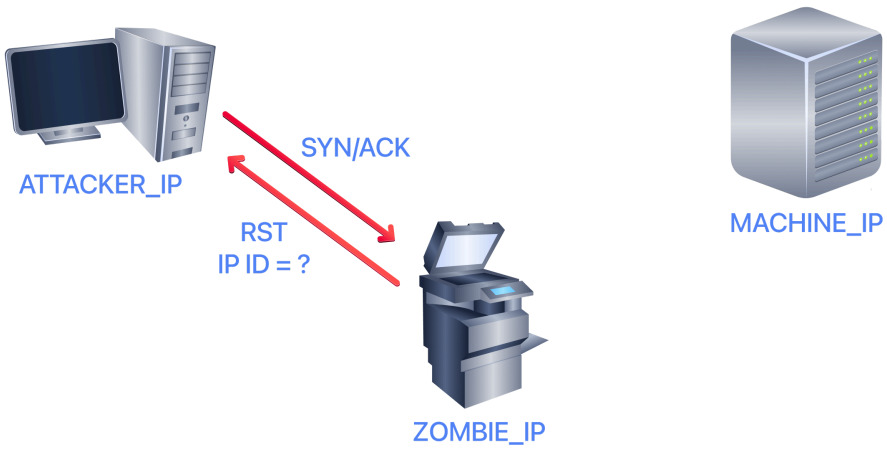
> If the TCP segment has a size of 64, and the -ff option is being used, how many IP fragments will you get? 4

7. Idle/Zombie Scan

Spoofing the source IP address can be an effective way to conduct stealthy scans. However, spoofing will only work in specific network setups. It requires you to be in a position to monitor traffic. Considering these limitations, spoofing your IP address is unlikely to be useful; however, we can give it a boost with the idle scan. The idle scan, or zombie scan, requires an idle system connected to the network that you can communicate with. Practically, Nmap will make each probe appear to come from the idle (zombie) host, then check whether the idle (zombie) host received any response to the spoofed probe. This is accomplished by checking the IP identification (IP ID) value in the IP header. You can run an idle scan using `nmap -sI ZOMBIE_IP MACHINE_IP`, where `ZOMBIE_IP` is the IP address of the idle host (zombie). The idle (zombie) scan requires the following three steps to discover whether a port is open:

1. Trigger the idle host to respond so that you can record the current IP ID on the idle host.
2. Send a SYN packet to a TCP port on the target. The packet should be spoofed to appear to come from the idle host's IP address (zombie).
3. Trigger the idle machine again to respond so that you can compare the new IP ID with the one received earlier.

Let’s explain with figures. In the figure below, we have the attacker system probing an idle machine, a multi-function printer. By sending a SYN/ACK, it responds with an RST packet containing its newly incremented IP ID.



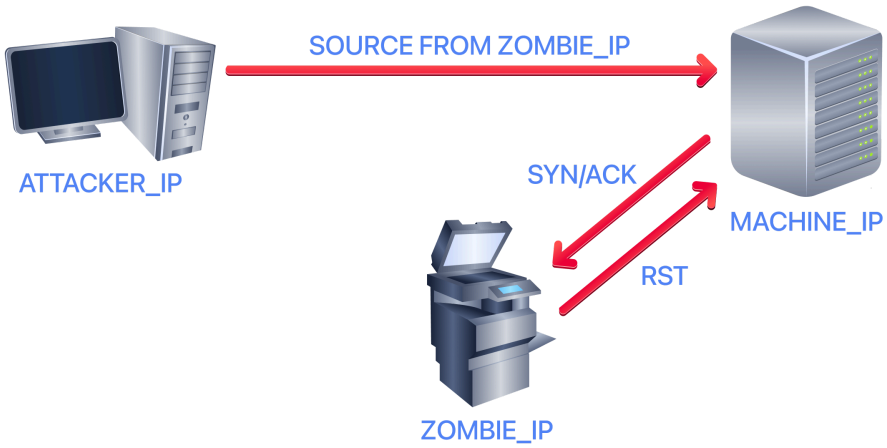
Attacker system communicates with an idle system to find its current IP ID

The attacker will send a SYN packet to the TCP port they want to check on the target machine in the next step. However, this packet will use the idle host (zombie) IP address as the source. Three scenarios would arise. In the first scenario, shown in the figure below, the TCP port is closed; therefore, the target machine responds to the idle host with an RST packet. The idle host does not respond; hence, its IP ID is not incremented.



Attacker system sends to target machine
a SYN packet spoofed as sent by the idle system.
Case: Port is closed.

In the second scenario, as shown below, the TCP port is open, so the target machine responds to the idle host (zombie) with a SYN/ACK. The idle host responds to this unexpected packet with an RST, incrementing its IP ID.



Attacker system sends to target machine
a SYN packet spoofed as sent by the idle system.
Case: Port is open.

In the third scenario, the target machine does not respond at all due to firewall rules. This lack of response will result in the same outcome as with a closed port: the idle host won't increment the IP ID. For the final step, the attacker sends another SYN/ACK to the idle host. The idle host responds with an RST

packet, incrementing the IP ID by one again. The attacker needs to compare the IP ID of the RST packet received in the first step with the IP ID of the RST packet received in this third step. If the difference is 1, it means the port on the target machine was closed or filtered. However, if the difference is 2, it means that the port on the target was open. It is worth repeating that this scan is called an idle scan because selecting an idle host is essential to its accuracy. If the “idle host” is busy, all the returned IP IDs would be useless.

> You discovered a rarely-used network printer with the IP address 10.10.5.5, and you decide to use it as a zombie in your idle scan. What argument should you add to your Nmap command?

-sI 10.10.5.5

8. Getting More Details

You might consider adding `--reason` if you want Nmap to provide more details regarding its reasoning and conclusions. Consider the two scans below to the system; however, the latter adds `--reason`.

```
pentester@TryHackMe$ sudo nmap -sS MACHINE_IP

Starting Nmap 7.60 ( https://nmap.org ) at 2021-08-30 10:39 B
ST
Nmap scan report for ip-10-10-252-27.eu-west-1.compute.intern
al (10.10.252.27)
Host is up (0.0020s latency).
Not shown: 994 closed ports
PORT STATE SERVICE
22/tcp open ssh
25/tcp open smtp
80/tcp open http
110/tcp open pop3
111/tcp open rpcbind
143/tcp open imap
MAC Address: 02:45:BF:8A:2D:6B (Unknown)
```

```
Nmap done: 1 IP address (1 host up) scanned in 1.60 seconds
```

```
pentester@TryHackMe$ sudo nmap -sS --reason MACHINE_IP

Starting Nmap 7.60 ( https://nmap.org ) at 2021-08-30 10:40 B
ST
Nmap scan report for ip-10-10-252-27.eu-west-1.compute.intern
al (10.10.252.27)
Host is up, received arp-response (0.0020s latency).
Not shown: 994 closed ports
Reason: 994 resets
PORT STATE SERVICE REASON
22/tcp open ssh syn-ack ttl 64
25/tcp open smtp syn-ack ttl 64
80/tcp open http syn-ack ttl 64
110/tcp open pop3 syn-ack ttl 64
111/tcp open rpcbind syn-ack ttl 64
143/tcp open imap syn-ack ttl 64
MAC Address: 02:45:BF:8A:2D:6B (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 1.59 seconds
```

Providing the `--reason` flag gives us the explicit reason why Nmap concluded that the system is up or a particular port is open. In the console output above, we can see that this system is considered online because Nmap "received arp-response." On the other hand, we know the SSH port is open because Nmap received a "syn-ack" packet. For more detailed output, you can consider using `-v` for verbose output or `-vv` for even more verbosity.

```
pentester@TryHackMe$ sudo nmap -sS -vv MACHINE_IP

Starting Nmap 7.60 ( https://nmap.org ) at 2021-08-30 10:41 B
ST
Initiating ARP Ping Scan at 10:41
```

```
Scanning 10.10.252.27 [1 port]
Completed ARP Ping Scan at 10:41, 0.22s elapsed (1 total host
s)
Initiating Parallel DNS resolution of 1 host. at 10:41
Completed Parallel DNS resolution of 1 host. at 10:41, 0.00s
elapsed
Initiating SYN Stealth Scan at 10:41
Scanning ip-10-10-252-27.eu-west-1.compute.internal (10.10.25
2.27) [1000 ports]
Discovered open port 22/tcp on 10.10.252.27
Discovered open port 25/tcp on 10.10.252.27
Discovered open port 80/tcp on 10.10.252.27
Discovered open port 110/tcp on 10.10.252.27
Discovered open port 111/tcp on 10.10.252.27
Discovered open port 143/tcp on 10.10.252.27
Completed SYN Stealth Scan at 10:41, 1.25s elapsed (1000 tota
l ports)
Nmap scan report for ip-10-10-252-27.eu-west-1.compute.intern
al (10.10.252.27)
Host is up, received arp-response (0.0019s latency).
Scanned at 2021-08-30 10:41:02 BST for 1s
Not shown: 994 closed ports
Reason: 994 resets
PORT STATE SERVICE REASON
22/tcp open ssh syn-ack ttl 64
25/tcp open smtp syn-ack ttl 64
80/tcp open http syn-ack ttl 64
110/tcp open pop3 syn-ack ttl 64
111/tcp open rpcbind syn-ack ttl 64
143/tcp open imap syn-ack ttl 64
MAC Address: 02:45:BF:8A:2D:6B (Unknown)

Read data files from: /usr/bin/../share/nmap
Nmap done: 1 IP address (1 host up) scanned in 1.59 seconds
Raw packets sent: 1002 (44.072KB) | Rcvd: 1002 (40.092KB)
```

If `-vv` does not satisfy your curiosity, you can use `-d` for debugging details or `-dd` for even more details. You can guarantee that using `-d` will create an output that extends beyond a single screen.

> Use Nmap with nmap -sS -F --reason MACHINE_IP to scan the VM. What is the reason provided for the stated port(s) being open?

syn-ack

```
root@ip-10-112-91-113:~# sudo nmap -sS -F --reason 10.112.141.113
sudo: unable to resolve host ip-10-112-91-113: Name or service not known
Starting Nmap 7.80 ( https://nmap.org ) at 2026-05-26 09:14 BST
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or sp
ecify valid servers with --dns-servers
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled.
 Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 10.112.141.113
Host is up, received echo-reply ttl 64 (0.0011s latency).
Not shown: 95 filtered ports
Reason: 88 no-responses and 7 admin-prohibiteds
PORT     STATE  SERVICE REASON
22/tcp   open   ssh     syn-ack ttl 64
25/tcp   open   smtp    syn-ack ttl 64
80/tcp   open   http    syn-ack ttl 64
443/tcp  closed https   reset ttl 64
5000/tcp open   upnp    syn-ack ttl 64

Nmap done: 1 IP address (1 host up) scanned in 2.20 seconds
```

9. Summary-6

Port Scan Type	Example Command
TCP Null Scan	sudo nmap -sN MACHINE_IP
TCP FIN Scan	sudo nmap -sF MACHINE_IP
TCP Xmas Scan	sudo nmap -sX MACHINE_IP
TCP Maimon Scan	sudo nmap -sM MACHINE_IP
TCP ACK Scan	sudo nmap -sA MACHINE_IP
TCP Window Scan	sudo nmap -sW MACHINE_IP
Custom TCP Scan	sudo nmap --scanflags URGACKPSHRSTSYNFIN MACHINE_IP
Spoofed Source IP	sudo nmap -S SPOOFED_IP MACHINE_IP

Port Scan Type	Example Command
Spoofed MAC Address	--spoof-mac SPOOFED_MAC
Decoy Scan	nmap -D DECOY_IP,ME MACHINE_IP
Idle (Zombie) Scan	sudo nmap -sI ZOMBIE_IP MACHINE_IP
Fragment IP data into 8 bytes	-f
Fragment IP data into 16 bytes	-ff

Option	Purpose
--source-port PORT_NUM	Specify source port number
--data-length NUM	Append random data to reach the given length

These scan types rely on setting TCP flags in unexpected ways to prompt ports for a reply. Null, FIN, and Xmas scans provoke a response from closed ports, while Maimon, ACK, and Window scans provoke a response from open and closed ports.

Option	Purpose
--reason	explains how Nmap made its conclusion
-v	verbose
-vv	very verbose
-d	debugging
-dd	more details for debugging

5. Nmap Post Port Scans

1. Service Detection

Once Nmap discovers open ports, you can probe each port to identify the service running on it. Further investigation of open ports is essential, as the pentester can

use this information to determine whether the service has known vulnerabilities. Join Vulnerabilities 101 to learn more about searching for vulnerable services. Adding `-sV` to your Nmap command will collect and determine service and version information for the open ports. You can control the intensity with `--version-intensity` LEVEL where the level ranges from 0(the lightest) to 9(the most complete). `-sV --version-light` has an intensity of 2, while `-sV --version-all` has an intensity of 9. It is important to note that using `-sV` will force Nmap to proceed with the TCP 3-way handshake and establish the connection. The connection establishment is necessary because Nmap cannot discover the version without establishing a connection fully and communicating with the listening service. In other words, a stealth SYN scan `-sS` is not possible when the -`sV` option is chosen. In the attached AB, enter the following command:

```
root@ip-10-10-166-81:~# sudo nmap -sV --version-light 10.201.
118.127
sudo: unable to resolve host ip-10-10-166-81: Name or service
not known
Starting Nmap 7.80 ( https://nmap.org ) at 2026-02-18 07:35 G
MT
mass_dns: warning: Unable to open /etc/resolv.conf. Try using
--system-dns or specify valid servers with --dns-servers
mass_dns: warning: Unable to determine any DNS servers. Rever
se DNS is disabled. Try using --system-dns or specify valid s
ervers with --dns-servers
Nmap scan report for 10.201.118.127
Host is up (0.071s latency).
Not shown: 992 closed ports
PORT    STATE SERVICE  VERSION
22/tcp  open  ssh      OpenSSH 9.2p1 Debian 2+deb12u3 (protoc
ol 2.0)
25/tcp  open  smtp     Postfix smtpd
80/tcp  open  http     nginx 1.22.1
110/tcp open  pop3     Dovecot pop3d
111/tcp open  rpcbind
143/tcp open  imap     Dovecot imapd
993/tcp open  ssl/imap Dovecot imapd
```

```
995/tcp open  ssl/pop3 Dovecot pop3d
Service Info: Host:  debra2.thm.local; OS: Linux; CPE: cpe:/
o:linux:linux_kernel

Service detection performed. Please report any incorrect resu
lts at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.49 seconds
```

The console output above shows a simple Nmap stealth SYN scan with the `-sV` option. Adding the `-sV` option leads to a new column in the output showing the version for each detected service. For instance, in the case of TCP port 22 being open, instead of `22/tcp open ssh`, we obtain `22/tcp open ssh OpenSSH 6.7p1 Debian 5+deb8u8 (protocol 2.0)`. Notice that the SSH protocol is guessed as the service because TCP port 22 is open; Nmap didn't need to connect to port 22 to confirm. However, `-sV` required connecting to this open port to grab the service banner and any version information it can get, such as `nginx 1.6.2`. Hence, unlike the *service* column, the *version* column is not a guess.

> What is the detected version for port 143? IMAP - Dovecot imapd

> Which service did not have a version detected with `--version-light`? rpcbind

```
root@ip-10-112-111-115:~# sudo nmap -sV --version-light 10.112.129.136
sudo: unable to resolve host ip-10-112-111-115: Name or service not known
Starting Nmap 7.80 ( https://nmap.org ) at 2026-05-26 09:31 BST
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or sp
ecify valid servers with --dns-servers
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled.
 Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 10.112.129.136
Host is up (0.0059s latency).
Not shown: 992 closed ports
PORT    STATE SERVICE  VERSION
22/tcp  open  ssh      OpenSSH 9.2p1 Debian 2+deb12u3 (protocol 2.0)
25/tcp  open  smtp     Postfix smtpd
80/tcp  open  http     nginx 1.22.1
110/tcp open  pop3     Dovecot pop3d
111/tcp open  rpcbind
143/tcp open  imap     Dovecot imapd
993/tcp open  ssl/imap Dovecot imapd
995/tcp open  ssl/pop3 Dovecot pop3d
Service Info: Host:  debra2.thm.local; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap
.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.56 seconds
```

2. OS Detection and Traceroute

OS Detection: Nmap can detect the Operating System (OS) of a target based on its behaviour and any telltale signs in its network responses. OS detection can be enabled using `-O`; this is an *uppercase O* as in OS. In this example, we will run `nmap -sS -O MACHINE_IP` on the AttackBox.

```
root@ip-10-10-166-81:~# sudo nmap -sS -O MACHINE_IP
sudo: unable to resolve host ip-10-10-166-81: Name or service
not known
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-18 08:47 +
0000
mass_dns: warning: Unable to open /etc/resolv.conf. Try using
--system-dns or specify valid servers with --dns-servers: No
such file or directory (2)
mass_dns: warning: Unable to determine any DNS servers. Rever
se DNS is disabled. Try using --system-dns or specify valid s
ervers with --dns-servers
Nmap scan report for 10.201.118.127
```

```
Host is up (0.070s latency).
Not shown: 992 closed tcp ports (reset)
PORT    STATE SERVICE
22/tcp  open  ssh
25/tcp  open  smtp
80/tcp  open  http
110/tcp open  pop3
111/tcp open  rpcbind
143/tcp open  imap
993/tcp open  imaps
995/tcp open  pop3s
No exact OS matches for host (If you know what OS is running
on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.98%E=4%D=2/18%OT=22%CT=1%CU=40131%PV=Y%DS=3%DC=I%
G=Y%TM=69957C9
OS:D%P=x86_64-unknown-linux-gnu)SEQ(SP=103%GCD=1%ISR=10B%TI=
Z%CI=Z%II=I%TS=
OS:A)SEQ(SP=103%GCD=1%ISR=10C%TI=Z%CI=Z%II=I%TS=A)SEQ(SP=105%
GCD=1%ISR=10D%
OS:TI=Z%CI=Z%II=I%TS=A)SEQ(SP=106%GCD=1%ISR=108%TI=Z%CI=Z%II=
I%TS=A)SEQ(SP=
OS:106%GCD=2%ISR=109%TI=Z%CI=Z%II=I%TS=A)OPS(O1=M210CST11NW7%
O2=M210CST11NW
OS:7%O3=M210CNNT11NW7%O4=M210CST11NW7%O5=M210CST11NW7%O6=M210
CST11)WIN(W1=F
OS:4B3%W2=F4B3%W3=F4B3%W4=F4B3%W5=F4B3%W6=F4B3)ECN(R=Y%DF=Y%T
=40%W=F507%O=M
OS:210CNNSNW7%CC=Y%Q=)T1(R=Y%DF=Y%T=40%S=O%A=S+%F=AS%RD=0%Q=)
T2(R=N)T3(R=N)
OS:T4(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T5(R=Y%DF=Y%T=
40%W=0%S=Z%A=S
OS:+%F=AR%O=%RD=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=
0%Q=)T7(R=Y%DF=
OS:Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=1
64%UN=0%RIPL=G
```

```
OS:%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)

Network Distance: 3 hops

OS detection performed. Please report any incorrect results a
t https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.99 seconds
```

In this case, Nmap was unable to determine an exact operating system match for the target host. Although OS detection was performed successfully, the collected TCP/IP fingerprint did not closely match any known signatures in Nmap's database. As a result, Nmap returned the message "No exact OS matches for host." Despite the lack of a precise match, the fingerprint data still provides useful clues. For example, **TTL** (Time to Live) refers to a value in each network packet that decrements as it passes through routers. Linux systems typically respond with a TTL of 64, while Windows systems commonly use 128. **TCP** sequence behaviour refers to how a system generates and increments TCP sequence numbers, which vary between operating systems and kernel versions. Service responses, such as the banners and protocol quirks observed on open ports, also differ between OS families. Together, these signals strongly indicate that the target is running a 64-bit Linux operating system. For a deeper understanding of how Nmap builds and matches OS fingerprints, refer to the official Nmap OS detection documentation(opens in new tab). The absence of an exact match may be due to factors such as virtualisation, firewall filtering, cloud networking layers, kernel customisation, or network middleboxes that modify packet characteristics. This result highlights an important limitation of OS fingerprinting: while it is a powerful technique, it does not always produce definitive results. Modern systems and virtualised environments often alter TCP/IP stack behaviour, making exact identification more difficult.
Therefore, OS detection results should always be interpreted carefully and supported with additional reconnaissance techniques when necessary.

Traceroute: If you want Nmap to find the routers between you and the target, just add `--traceroute`. In the following example, Nmap appended a traceroute to its scan results. Note that Nmap's traceroute works slightly differently from the `traceroute` command found on Linux and macOS or `tracert` found on MS

Windows. Standard `traceroute` starts with a packet with a low TTL (Time to Live) and increases it until it reaches the target. Nmap's traceroute starts with a packet with a high TTL and keeps decrementing it. In the following example, we will execute `nmap -sS --traceroute MACHINE_IP` on the AttackBox. We can see that the hop count is 3.

```
root@ip-10-10-166-81:~# nmap -sS --traceroute 10.201.118.127
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-18 08:50 +
0000
mass_dns: warning: Unable to open /etc/resolv.conf. Try using
--system-dns or specify valid servers with --dns-servers: No
such file or directory (2)
mass_dns: warning: Unable to determine any DNS servers. Rever
se DNS is disabled. Try using --system-dns or specify valid s
ervers with --dns-servers
Nmap scan report for 10.201.118.127
Host is up (0.071s latency).
Not shown: 992 closed tcp ports (reset)
PORT    STATE SERVICE
22/tcp  open  ssh
25/tcp  open  smtp
80/tcp  open  http
110/tcp open  pop3
111/tcp open  rpcbind
143/tcp open  imap
993/tcp open  imaps
995/tcp open  pop3s

TRACEROUTE (using port 554/tcp)
HOP RTT      ADDRESS
1   ... 2
3   69.89 ms 10.201.118.127

Nmap done: 1 IP address (1 host up) scanned in 4.44 seconds
```

> Per nmap, which one is the closest OS match after running with the nmap with -O option against MACHINE_IP?

Linux

```
root@ip-10-112-111-115:/usr/share/nmap/scripts# cat http-robots.txt.nse
local http = require "http"
local nmap = require "nmap"
local shortport = require "shortport"
local strbuf = require "strbuf"
local table = require "table"

description = [[
Checks for disallowed entries in <code>/robots.txt</code> on a web server.

The higher the verbosity or debug level, the more disallowed entries are shown.
]]

---
--@output
-- 80/tcp  open   http    syn-ack
-- |  http-robots.txt: 156 disallowed entries (40 shown)
-- |  /news?output=xhtml& /search /groups /images /catalogs
-- |  /catalogues /news /nwshp /news?btcid=*& /news?btaid=*&
-- |  /setnewsprefs? /index.html? /? /addurl/image? /pagead/ /relpage/
-- |  /relcontent /sorry/ /imgres /keyword/ /u/ /univ/ /cobrand /custom
-- |  /advanced_group_search /googlesite /preferences /setprefs /swr /url /defau
lt
-- |  /m? /m/? /m/lcb /m/news? /m/setnewsprefs? /m/search? /wml?
-- |_ /wml/? /wml/search?
```

3. Nmap Scripting Engine (NSE)

A script is a piece of code that does not need to be compiled. In other words, it remains in its original human-readable form and does not need to be converted to machine language. Many programs provide additional functionality via scripts; moreover, scripts enable adding custom functionality that was not available via built-in commands. Similarly, Nmap supports scripts written in Lua. A part of Nmap, the Nmap Scripting Engine (NSE) is a Lua interpreter that allows Nmap to execute Nmap scripts written in Lua. However, we don't need to learn Lua to make use of Nmap scripts. Your Nmap default installation can easily contain close to 600 scripts. Take a look at your Nmap installation folder. On the AttackBox, navigate to the directory at `/usr/share/nmap/scripts`, and you will notice that there are hundreds of scripts conveniently named starting with the protocol they target. We

listed all the scripts starting with HTTP in the AttackBox console output below; we found more than 130. With future updates, you can only expect the number of installed scripts to increase. In the AB, enter the following command:

```
root@ip-10-10-166-81:/usr/share/nmap/scripts# ls http*
http-adobe-coldfusion-apsa1301.nse      http-passwd.nse
http-affiliate-id.nse                   http-phpmyadmin-dir-t
raversal.nse
http-apache-negotiation.nse             http-phpself-xss.nse
http-apache-server-status.nse           http-php-version.nse
http-aspnet-debug.nse                   http-proxy-brute.nse
http-auth-finder.nse                    http-put.nse
http-auth.nse                           http-qnap-nas-info.ns
e
http-avaya-ipoffice-users.nse           http-referer-checker.
nse
http-awstatstotals-exec.nse             http-rfi-spider.nse
http-axis2-dir-traversal.nse            http-ro
```

You can specify to use any or a group of these installed scripts; moreover, you can install other users' scripts and use them for your scans. Let's begin with the default scripts. You can choose to run the scripts in the default category using `--script=default` or simply adding `-sC`. In addition to default(opens in new tab), categories include auth, broadcast, brute, default, discovery, dos, exploit, external, fuzzer, intrusive, malware, safe, version, and vuln. A brief description is shown in the following table.

Script Category	Description
`auth`	Runs authentication-related scripts
`broadcast`	Discovers hosts by sending broadcast messages
`brute`	Performs brute-force password auditing against logins
`default`	Runs default scripts (same as `-sC`)
`discovery`	Retrieves accessible information, such as database tables and DNS names

Script Category	Description
`dos`	Detects servers vulnerable to Denial of Service (DoS)
`exploit`	Attempts to exploit various vulnerable services
`external`	Checks using a third-party service, such as Geoplugin and Virustotal
`fuzzer`	Launches fuzzing attacks
`intrusive`	Runs intrusive scripts such as brute-force attacks and exploitation
`malware`	Scans for backdoors
`safe`	Runs safe scripts that won't crash the target
`version`	Retrieves service versions
`vuln`	Checks for vulnerabilities or exploits in a vulnerable service

Some scripts belong to more than one category. Moreover, some scripts launch brute-force attacks against services, while others launch DoS attacks and exploit systems. Hence, it is crucial to be careful when selecting scripts to run to avoid crashing services or exploiting them. We will use Nmap to run a SYN scan against `MACHINE_IP` and execute the default scripts in the console shown below. The command is `sudo nmap -sS -sC MACHINE_IP`, where `-sC` will ensure that Nmap will execute the default scripts following the SYN scan. New details appear below. Take a look at the SSH service on port 22; Nmap identified all public keys associated with the running server. Consider another example, the HTTP service at port 80; Nmap retrieved the default page title. We can see that the page has been left as the default.

```
root@ip-10-10-166-81:/usr/share/nmap/scripts# sudo nmap -sS -
sC 10.201.118.127
sudo: unable to resolve host ip-10-10-166-81: Name or service
not known
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-18 09:44 +
0000
mass_dns: warning: Unable to open /etc/resolv.conf. Try using
--system-dns or specify valid servers with --dns-servers: No
such file or directory (2)
mass_dns: warning: Unable to determine any DNS servers. Rever
```

```
se DNS is disabled. Try using --system-dns or specify valid s
ervers with --dns-servers
Nmap scan report for 10.201.118.127
Host is up (0.070s latency).
Not shown: 992 closed tcp ports (reset)
PORT    STATE SERVICE
22/tcp  open  ssh
| ssh-hostkey:
|   256 a3:dc:d7:6b:7e:a4:4e:fa:af:60:f6:24:78:38:16:9e (ECDS
A)
|_  256 3c:e4:c0:5e:03:cb:65:aa:00:ed:29:fd:f1:d3:e6:a2 (ED25
519)
25/tcp  open  smtp
|_ssl-date: TLS randomness does not represent time
|_smtp-commands: debra2.thm.local, PIPELINING, SIZE 10240000,
VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN, CHU
NKING
| ssl-cert: Subject: commonName=debra2.thm.local
| Not valid before: 2021-08-10T12:10:58
|_Not valid after:  2031-08-08T12:10:58
```

You can also specify the script by name using `--script "SCRIPT-NAME"` or a pattern such as `--script "ftp*"`, which would include `ftp-brute`. If you are unsure what a script does, you can open the script file with a text reader, such as `less`, or a text editor. In the case of `ftp-brute`, it states: "Performs brute force password auditing against FTP servers." You have to be careful as some scripts are pretty intrusive. Moreover, some scripts might be for a specific server and, if chosen at random, will waste your time with no benefit. As usual, make sure that you are authorised to launch such tests on the target server. Let's consider a benign script, `http-date`, which we guess would retrieve the HTTP server date and time, and this is indeed confirmed in its description: "Gets the date from HTTP-like services. Also, it prints how much the date differs from local time..." On the AttackBox, we execute `sudo nmap -sS -n --script "http-date" MACHINE_IP` as shown in the console below.

```
root@ip-10-10-166-81:/usr/share/nmap/scripts#  sudo nmap -sS
-n --script "http-date" 10.201.118.127
```

```
sudo: unable to resolve host ip-10-10-166-81: Name or service
not known
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-18 09:46 +
0000
Nmap scan report for 10.201.118.127
Host is up (0.077s latency).
Not shown: 992 closed tcp ports (reset)
PORT    STATE SERVICE
22/tcp  open  ssh
25/tcp  open  smtp
80/tcp  open  http
|_http-date: Wed, 18 Feb 2026 09:46:15 GMT; +1h00m00s from lo
cal time.
110/tcp open  pop3
111/tcp open  rpcbind
143/tcp open  imap
993/tcp open  imaps
995/tcp open  pop3s

Nmap done: 1 IP address (1 host up) scanned in 1.80 seconds
```

Finally, you might expand the functionality of Nmap beyond the official Nmap scripts; you can write your own script or download Nmap scripts from the Internet. Downloading and using a Nmap script from the Internet holds a certain level of risk. So it is a good idea not to run a script from an author you don't trust.

> Knowing that Nmap scripts are saved in /usr/share/nmap/scripts on the AttackBox. What does the script http-robots.txt check for?

disallowed entries

> Can you figure out the name for the script that checks for the remote code execution vulnerability MS15-034 (CVE-2015-1635)?

http-vuln-cve2015-1635

> On the AttackBox, run Nmap with the default scripts -sC against MACHINE_IP. You will notice that a page is hosted on port 80. What is the http-title value?

Welcome to nginx on Debian!

Based on its description, the script ssh2-enum-algos “reports the number of algorithms (for encryption, compression, etc.) that the target SSH2 server offers.” What is the name of the server host key algorithm that relies on SHA2-512 and is supported by MACHINE_IP? rsa-sha2-512

```
root@ip-10-112-111-115:/usr/share/nmap/scripts# cat http-robots.txt.nse
local http = require "http"
local nmap = require "nmap"
local shortport = require "shortport"
local strbuf = require "strbuf"
local table = require "table"

description = [[
Checks for disallowed entries in <code>/robots.txt</code> on a web server.

The higher the verbosity or debug level, the more disallowed entries are shown.
]]

---
--@output
-- 80/tcp  open   http    syn-ack
-- |  http-robots.txt: 156 disallowed entries (40 shown)
-- |  /news?output=xhtml& /search /groups /images /catalogs
-- |  /catalogues /news /nwshp /news?btcid=*& /news?btaid=*&
-- |  /setnewsprefs? /index.html? /? /addurl/image? /pagead/ /relpage/
-- |  /relcontent /sorry/ /imgres /keyword/ /u/ /univ/ /cobrand /custom
-- |  /advanced_group_search /googlesite /preferences /setprefs /swr /url /defau
lt
-- |  /m? /m/? /m/lcb /m/news? /m/setnewsprefs? /m/search? /wml?
-- |_ /wml/? /wml/search?
```

```
root@ip-10-112-111-115:/usr/share/nmap/scripts# grep -i "MS15-034" *
http-vuln-cve2015-1635.nse:Checks for a remote code execution vulnerability (MS15-03
4) in Microsoft Windows systems (CVE2015-2015-1635).
http-vuln-cve2015-1635.nse:* https://technet.microsoft.com/library/security/MS15-034
http-vuln-cve2015-1635.nse:-- |   Remote Code Execution in HTTP.sys (MS15-034)
http-vuln-cve2015-1635.nse:-- |       https://technet.microsoft.com/en-us/library/se
curity/ms15-034.aspx
http-vuln-cve2015-1635.nse:    title = 'Remote Code Execution in HTTP.sys (MS15-034)
',
http-vuln-cve2015-1635.nse:      'https://technet.microsoft.com/en-us/library/securi
ty/ms15-034.aspx'
```

```
root@ip-10-112-111-115:/usr/share/nmap/scripts# nmap -sC 10.112.158.184
Starting Nmap 7.80 ( https://nmap.org ) at 2026-05-26 10:54 BST
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or specif
y valid servers with --dns-servers
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try
 using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 10.112.158.184
Host is up (0.0040s latency).
Not shown: 992 closed ports
PORT    STATE SERVICE
22/tcp  open  ssh
25/tcp  open  smtp
|_smtp-commands: debra2.thm.local, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS,
ENHANCEDSTATUSCODES, 8BITMIME, DSN, CHUNKING,
| ssl-cert: Subject: commonName=debra2.thm.local
| Not valid before: 2021-08-10T12:10:58
|_Not valid after:  2031-08-08T12:10:58
|_ssl-date: TLS randomness does not represent time
80/tcp  open  http
|_http-title: Welcome to nginx on Debian!
110/tcp open  pop3
|_pop3-capabilities: SASL CAPA UIDL AUTH-RESP-CODE TOP PIPELINING STLS RESP-CODES
```

```
root@ip-10-112-111-115:/usr/share/nmap/scripts# nmap -sS -n --script "ssh2-enum-algo
s" 10.112.158.184
Starting Nmap 7.80 ( https://nmap.org ) at 2026-05-26 10:58 BST
Nmap scan report for 10.112.158.184
Host is up (0.0016s latency).
Not shown: 992 closed ports
PORT    STATE SERVICE
22/tcp  open  ssh
| ssh2-enum-algos:
|   kex_algorithms: (11)
|       sntrup761x25519-sha512@openssh.com
|       curve25519-sha256
|       curve25519-sha256@libssh.org
|       ecdh-sha2-nistp256
|       ecdh-sha2-nistp384
|       ecdh-sha2-nistp521
|       diffie-hellman-group-exchange-sha256
|       diffie-hellman-group16-sha512
|       diffie-hellman-group18-sha512
|       diffie-hellman-group14-sha256
|       kex-strict-s-v00@openssh.com
|   server_host_key_algorithms: (4)
|       rsa-sha2-512
|       rsa-sha2-256
|       ecdsa-sha2-nistp256
|       ssh-ed25519
```

4.Saving the Output

Normal: As the name implies, the normal format is similar to the output you get on the screen when scanning a target. You can save your scan in normal format by

using `-oN FILENAME`; `N` stands for normal. In the AB, first enter the command `nmap -oN scan.nmap MACHINE_IP` and then issue the following command:

```
root@ip-10-10-166-81:/usr/share/nmap/scripts# cat scan.nmap
# Nmap 7.98 scan initiated Wed Feb 18 09:56:51 2026 as: nmap
-oN scan.nmap 10.201.118.127
mass_dns: warning: Unable to open /etc/resolv.conf. Try using
--system-dns or specify valid servers with --dns-servers: No
such file or directory (2)
mass_dns: warning: Unable to determine any DNS servers. Rever
se DNS is disabled. Try using --system-dns or specify valid s
ervers with --dns-servers
Nmap scan report for 10.201.118.127
Host is up (0.070s latency).
Not shown: 992 closed tcp ports (reset)
PORT    STATE SERVICE
22/tcp  open  ssh
25/tcp  open  smtp
80/tcp  open  http
110/tcp open  pop3
111/tcp open  rpcbind
143/tcp open  imap
993/tcp open  imaps
995/tcp open  pop3s# Nmap done at Wed Feb 18 09:56:52 2026 --
1 IP address (1 host up) scanned in 1.36 seconds
```

Grepable: The grepable format has its name from the command `grep`; grep stands for Global Regular Expression Printer. In simple terms, it makes filtering the scan output for specific keywords or terms efficient. You can save the scan result in a grepable format using `-oG FILENAME`. The scan output, displayed above in normal format, is shown in the console below using grepable format. The normal output is 21 lines; however, the grepable output is only 4 lines. The main reason is that Nmap wants to make each line meaningful and complete when the user applies `grep`. As a result, the lines in the grepable output are so long that they are not convenient to read compared to the normal output. A sample response is shown below:

```
pentester@TryHackMe$ cat MACHINE_IP_scan.gnmap
# Nmap 7.60 scan initiated Fri Sep 10 05:14:19 2021 as: nmap
-sS -sV -O -oG MACHINE_IP_scan MACHINE_IP
Host: MACHINE_IP    Status: Up
Host: MACHINE_IP    Ports: 22/open/tcp//ssh//OpenSSH 6.7p1 De
bian 5+deb8u8 (protocol 2.0)/, 25/open/tcp//smtp//Postfix smt
pd/, 80/open/tcp//http//nginx 1.6.2/, 110/open/tcp//pop3//Dov
ecot pop3d/, 111/open/tcp//rpcbind//2-4 (RPC #100000)/, 143/o
pen/tcp//imap//Dovecot imapd/   Ignored State: closed (994) O
S: Linux 3.13   Seq Index: 257  IP ID Seq: All zeros# Nmap do
ne at Fri Sep 10 05:14:28 2021 -- 1 IP address (1 host up) sc
anned in 9.99 seconds
```

An example use of `grep` is `grep KEYWORD TEXT_FILE`; this command displays all lines containing the provided keyword. Let's compare the output of using `grep` on normal output and grepable output. You will notice that the former does not include the host's IP address. Instead, it returned `80/tcp open http nginx 1.6.2`, making it very inconvenient when sifting through the scan results of multiple systems. However, the latter provides enough information, such as the host's IP address, in each line to make it complete.

```
pentester@TryHackMe$ grep http MACHINE_IP_scan.nmap
80/tcp  open  http    nginx 1.6.2
OS and Service detection performed. Please report any incorre
ct results at https://nmap.org/submit/ .
```

```
pentester@TryHackMe$ grep http MACHINE_IP_scan.gnmap
Host: MACHINE_IP    Ports: 22/open/tcp//ssh//OpenSSH 6.7p1 De
bian 5+deb8u8 (protocol 2.0)/, 25/open/tcp//smtp//Postfix smt
pd/, 80/open/tcp//http//nginx 1.6.2/, 110/open/tcp//pop3//Dov
ecot pop3d/, 111/open/tcp//rpcbind//2-4 (RPC #100000)/, 143/o
pen/tcp//imap//Dovecot imapd/   Ignored State: closed (994) O
S: Linux 3.13   Seq Index: 257  IP ID Seq: All zeros
```

XML: The third format is XML. You can save the scan results in XML format using `-oX FILENAME`. The XML format would be most convenient for processing the output in other programs. Conveniently enough, you can save the scan output in all three formats using `-oA FILENAME` to combine `-oN`, `-oG`, and `-oX` for normal, grepable, and XML.

Script Kiddie: A fourth format is script kiddie. You can see that this format is useless if you want to search the output for any interesting keywords or keep the results for future reference. However, you can use it to save the output of the scan `nmap -sS 127.0.0.1 -oS FILENAME`, display the output filename, and look 31337 in front of friends who are not tech-savvy.

```
pentester@TryHackMe$ cat MACHINE_IP_scan.kiddie

$tart!ng nMaP 7.60 ( httpz://nMap.0rG ) at 2021-09-10 05:17 B
$T
Nmap scan rEp0rt f0r |p-10-10-161-170.EU-w3$t-1.C0mputE.intEr
naL (10.10.161.170)
HOSt !s uP (0.00095s LatEncy).
N0T $H0wn: 994 closed pOrtS
PoRT    st4Te SeRViC3 VERS1on
22/tcp  Open  ssH     Op3n$$H 6.7p1 Deb|an 5+dEb8u8 (pr0t0COl
2.0)
25/tCp  Op3n  SmTp    P0$Tf!x Smtpd
80/tcp  0p3n  http    Ng1nx 1.6.2
110/tCP 0pen  pOP3    d0v3coT P0p3D
111/TcP op3n  RpcbInd 2-4 (RPC #100000)
143/Tcp opEn  Imap    Dovecot 1mApd
mAC 4Ddr3sz: 02:40:e7:B5:B6:c5 (Unknown)
Netw0rk d!stanc3: 1 h0p
$3rv1c3 InFO: Ho$t:  dEBra2.thM.lOcal; 0s: Linux; cPe: cP3:/
0:linux:l|nux_k3rnel

0S and servIc3 D3tEcti0n pErf0rm3d. Plea$e r3p0rt any !nc0Rre
cT rE$ultz at hTtpz://nmap.0rg/$ubmit/ .
Nmap d0nE: 1 |P addr3SS (1 hoSt up) $CaNnEd !n 21.80 s3c0Ndz
```

> What parameter is used to save the output in a greppable format? -oG

> Is it possible to save Nmap output in XML format (yea/nay)? yea

5. Summary

In this room, we learned how to detect running services, their versions, and the host operating system. We learned how to enable traceroute and how to select one or more scripts to aid in penetration testing. Finally, we covered the different formats for saving scan results for future reference. The table below summarises the most important options we covered in this room.

Option	Meaning
`-sV`	Determine service/version info on open ports
`-sV --version-light`	Try the most likely probes (2)
`-sV --version-all`	Try all available probes (9)
`-O`	Detect OS
`--traceroute`	Run traceroute to the target
`--script=SCRIPTS`	Nmap scripts to run
`-sC` or `--script=default`	Run default scripts
`-A`	Equivalent to `-sV -O -sC --traceroute`
`-oN`	Save output in normal format
`-oG`	Save output in a grepable format
`-oX`	Save output in XML format
`-oA`	Save output in normal, XML and Grepable formats

6. Net Sec Challenge

1. What is the highest port number that is open and less than 10,000? 8081

```
root@ip-10-112-125-58:~# nmap -T4 -sT -p- -A 10.112.162.89
Starting Nmap 7.80 ( https://nmap.org ) at 2026-05-26 11:50 BST
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or sp
ecify valid servers with --dns-servers
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled.
 Try using --system-dns or specify valid servers with --dns-servers
Stats: 0:01:59 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 71.43% done; ETC: 11:52 (0:00:46 remaining)
Nmap scan report for 10.112.162.89
Host is up (0.00076s latency).
Not shown: 65528 closed ports
PORT      STATE SERVICE     VERSION
22/tcp    open  ssh         (protocol 2.0)
| fingerprint-strings:
|   NULL:
|_    SSH-2.0-OpenSSH_8.2p1 THM{946219583339}
80/tcp    open  http        THM{MySpecialServer007}
| fingerprint-strings:
|   FourOhFourRequest:
|     HTTP/1.0 404 Not Found
|     Content-Type: text/html
|     Content-Length: 341
|     Connection: close
|     Date: Tue, 26 May 2026 10:50:23 GMT
|     Server: THM{MySpecialServer007}
|     <?xml version="1.0" encoding="iso-8859-1"?>
|     <!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN"
|     "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">
|     <html xmlns="http://www.w3.org/1999/xhtml" xml:lang="en" lang="en">
|     <head>
|     <title>404 Not Found</title>
```

2. There is an open port outside the common 1000 ports; it is above 10,100. What is it? 10121

```
|_http-server-header: THM{MySpecialServer007}
|_http-title: Welcome
139/tcp   open  netbios-ssn Samba smbd 4.6.2
445/tcp   open  netbios-ssn Samba smbd 4.6.2
8081/tcp  open  http        Node.js (Express middleware)
|_http-title: Site doesn't have a title (text/html; charset=utf-8).
10001/tcp open  scp-config?
10121/tcp open  ftp         vsftpd 3.0.5
2 services unrecognized despite returning data. If you know the service/version,
 please submit the following fingerprints at https://nmap.org/cgi-bin/submit.cgi
?new-service :
```

3. How many TCP ports are open? 7

```
|_http-title: Welcome
139/tcp   open  netbios-ssn Samba smbd 4.6.2
445/tcp   open  netbios-ssn Samba smbd 4.6.2
8081/tcp  open  http        Node.js (Express middleware)
|_http-title: Site doesn't have a title (text/html; charset=utf-8).
10001/tcp open  scp-config?
10121/tcp open  ftp         vsftpd 3.0.5
2 services unrecognized despite returning data. If you know the service/ver
fingerprints at https://nmap.org/cgi-bin/submit.cgi?new-service :
==============NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)==============
SF-Port22-TCP:V=7.80%I=7%D=5/26%Time=6A157AEB%P=x86_64-pc-linux-gnu%r(NULL
SF:,2A,"SSH-2\.0-OpenSSH_8\.2p1\x20THM{946219583339}\x20\r\n");
==============NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)==============
SF-Port80-TCP:V=7.80%I=7%D=5/26%Time=6A157AEB%P=x86_64-pc-linux-gnu%r(GetR
SF:equest,1E4,"HTTP/1\.0\x20200\x20OK\r\nVary:\x20Accept-Encoding\r\nConte
SF:nt-Type:\x20text/html\r\nAccept-Ranges:\x20bytes\r\nETag:\x20\"57535765
SF:0\"\r\nLast-Modified:\x20Tue,\x2024\x20Feb\x202026\x2006:00:52\x20GMT\r
SF:\nContent-Length:\x20220\r\nConnection:\x20close\r\nDate:\x20Tue,\x2026
SF:\x20May\x202026\x2010:50:17\x20GMT\r\nServer:\x20THM{MySpecialServer007
```

4. On port 80, what is the service version value? THM{MySpecialServer007}

```
|_http-server-header: THM{MySpecialServer007}
|_http-title: Welcome
139/tcp   open  netbios-ssn Samba smbd 4.6.2
445/tcp   open  netbios-ssn Samba smbd 4.6.2
8081/tcp  open  http        Node.js (Express middleware)
|_http-title: Site doesn't have a title (text/html; charset=utf-8).
10001/tcp open  scp-config?
10121/tcp open  ftp         vsftpd 3.0.5
```

5. What is the flag hidden in the SSH server header? THM{946219583339}

```
root@ip-10-112-125-58:~# echo eddie>users.txt
root@ip-10-112-125-58:~# echo quinn>>users.txt
root@ip-10-112-125-58:~# ls
burp.json   Downloads     Postman  snap              users.txt
CTFBuilder  Instructions  Rooms    thinclient_drives
Desktop     Pictures      Scripts  Tools
root@ip-10-112-125-58:~# hydra ftp://10.112.162.89:10121 -L users.txt -P /usr/share/wordlists/rockyou.txt

Hydra v9.0 (c) 2019 by van Hauser/THC - Please do not use in military or secret service organizations, or
 for illegal purposes.

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-26 12:23:19
[DATA] max 16 tasks per 1 server, overall 16 tasks, 28688796 login tries (l:2/p:14344398), ~1793050 tries
 per task
[DATA] attacking ftp://10.112.162.89:10121/
[10121][ftp] host: 10.112.162.89   login: eddie   password: softball
[10121][ftp] host: 10.112.162.89   login: quinn   password: cookie
1 of 1 target successfully completed, 2 valid passwords found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-26 12:24:08
root@ip-10-112-125-58:~#
```

6. We have an FTP server listening on a nonstandard port. What is the version of the FTP server? vsftpd 3.0.5

7. We learned two usernames using social engineering: eddie and quinn. What is the flag hidden in one of these two account files and accessible via FTP? THM{QUINN_IS_BACK007}

8. Browsing to http://MACHINE_IP:8081 displays a small challenge that will give you a flag once you solve it. What is the flag? THM{NMAP_CHAMPION001}